

SOAR **PLAYBOOK** **ENGINEERING** **HANDBOOK**

2026 Edition

100 Configuration-Ready
Detection & Response Workflows

IZZMIER IZZUDDIN ZULKEPLI

Contents - 100 Playbooks

Email & Collaboration

- 001. Suspicious Phishing Link
- 002. Malicious Email Attachment
- 003. Business Email Compromise / Payment Fraud
- 004. QR Code Phishing
- 005. AiTM Phishing and Session Token Theft
- 006. Device Code Phishing / OAuth Token Capture
- 007. ClickFix / Malicious Copy-Paste Execution
- 008. MFA Fatigue / Push Bombing
- 009. OAuth Consent Phishing
- 010. Suspicious Inbox Rule
- 011. Unauthorized Mailbox Forwarding
- 012. Internal Account Sending Phish
- 013. Executive Impersonation / Display Name Spoofing
- 014. Email Bombing / Helpdesk Social Engineering
- 015. Malicious SharePoint / OneDrive / Teams File Share

Identity & Active Directory

- 016. Password Spray
- 017. Credential Stuffing
- 018. Impossible Travel / Anomalous Sign-In
- 019. Risky User / Unfamiliar Sign-In
- 020. Privileged Account Compromise
- 021. Break-Glass Account Use
- 022. Service Account / Non-Human Identity Compromise
- 023. Secret / API Key Exposure
- 024. New MFA Method Registration
- 025. Privileged Role Assignment
- 026. Account Creation + Privilege Escalation
- 027. Kerberoasting
- 028. DCSync
- 029. Golden / Silver Ticket Indicators
- 030. AD Group / GPO Tampering

Endpoint & Malware

- 031. Endpoint Malware Detection
- 032. Ransomware Precursors
- 033. Active Ransomware Encryption
- 034. Data Wiper / Destructive Attack
- 035. Suspicious PowerShell
- 036. Encoded / Obfuscated Command
- 037. LOLBin Abuse
- 038. Credential Dumping / LSASS Access
- 039. EDR Tampering / Disabled
- 040. Antivirus Disabled
- 041. Log Clearing / Event Log Tampering
- 042. Scheduled Task Persistence
- 043. Service Creation Persistence
- 044. Registry Run Key Persistence
- 045. Remote Monitoring / Management Tool Abuse
- 046. PsExec Lateral Movement
- 047. WMI Lateral Movement
- 048. RDP Lateral Movement
- 049. SMB / Admin Share Lateral Movement
- 050. Suspicious Script / Office Macro Execution

Network & Perimeter

- 051. Command-and-Control Beaconsing
- 052. DNS Tunneling
- 053. DGA / Anomalous DNS
- 054. TOR / Anonymous Proxy Traffic
- 055. Inbound Threat-Intel IOC Hit
- 056. Outbound Threat-Intel IOC Hit
- 057. Internal Network Scanning / Recon
- 058. External Scanning Against Public Asset
- 059. Exploitation of Public-Facing Application
- 060. VPN Brute Force / Account Takeover
- 061. Firewall Critical Configuration Change

- 062. Network Device Admin Compromise
- 063. IPS / IDS Critical Exploit Alert
- 064. Unexpected East-West Traffic
- 065. Unauthorized Remote Access Port Exposure

Web & API

- 066. SQL Injection
- 067. Command Injection
- 068. Path Traversal / LFI / RFI
- 069. Server-Side Request Forgery (SSRF)
- 070. Web Shell Detection
- 071. Web Credential Stuffing
- 072. API Abuse / Token Misuse
- 073. API Key Abuse
- 074. Malicious Bot / Automated Abuse
- 075. Web Defacement / Integrity Change

Cloud & SaaS

- 076. Mass Cloud File Download
- 077. Suspicious External Sharing
- 078. Public Cloud Storage Exposure
- 079. Cloud Audit Logging Disabled
- 080. AWS Root Account Use
- 081. AWS Access Key Compromise
- 082. Azure Subscription Privilege Abuse
- 083. GCP Service Account Key Abuse
- 084. Cloud VM Cryptomining
- 085. SaaS Admin Configuration Change
- 086. Compromised OAuth / Enterprise Application
- 087. Cloud Snapshot / Backup Exfiltration
- 088. Cross-Tenant / Guest Account Abuse

DevSecOps & Containers

- 089. CI/CD Pipeline Compromise
- 090. Poisoned Pipeline Execution / Malicious Workflow
- 091. Malicious Package / Dependency Supply Chain
- 092. Repository Token / PAT Compromise
- 093. Code Signing Key Compromise
- 094. Kubernetes Suspicious Exec / Privilege Abuse
- 095. Container Escape / Privileged Container

Data Protection & Resilience

- 096. DLP Sensitive Data Exfiltration
- 097. Database Bulk Export / Dump
- 098. Insider Threat Anomalous Access
- 099. Backup Tampering / Recovery Impairment

Major Incident Management

- 100. Multi-Stage Major Incident / Enterprise Orchestrator

PB-001 - Suspicious Phishing Link

Domain: Email & Collaboration

Objective	Detect and contain credential-harvesting or malware-delivery links before account or endpoint compromise.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Email gateway/user report flags a URL, URL reputation is suspicious, or multiple recipients received the same lure.
ATT&CK v19.2 mapping	T1566.002 Phishing: Spearphishing Link; T1204.001 User Execution: Malicious Link
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events

- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Email gateway/user report flags a URL, URL reputation is suspicious, or multiple recipients received the same lure.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-001. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Email gateway/user report flags a URL, URL reputation is suspicious, or multiple recipients received the same lure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-001_SUSPICIOUS_PHISHING_LINK
ON: alert where rule_family == "SUSPICIOUS_PHISHING_LINK"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Suspicious Phishing Link. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Suspicious Phishing Link' involving user001@orionbank.example / WKS-117 and source 203.0.113.8.
09:03	Normalize	SOAR creates SOAR-001, stores raw event, extracts IP 203.0.113.8, domain case001-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.8 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.12 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence

Time	Stage	Simulation
		indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-001.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-002 - Malicious Email Attachment

Domain: Email & Collaboration

Objective	Analyze, remove, and contain malicious attachments delivered through email.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Attachment sandbox/AV verdict is malicious or suspicious; user reports a file; EDR observes post-delivery execution.
ATT&CK v19.2 mapping	T1566.001 Phishing: Spearphishing Attachment; T1204.002 User Execution: Malicious File
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Attachment sandbox/AV verdict is malicious or suspicious; user reports a file; EDR observes post-delivery execution.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-002. Parse the originating alert into a common schema: detection	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
	time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Attachment sandbox/AV verdict is malicious or suspicious; user reports a file; EDR observes post-delivery execution. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-002_MALICIOUS_EMAIL_ATTACHMENT
ON: alert where rule_family == "MALICIOUS_EMAIL_ATTACHMENT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Malicious Email Attachment. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Malicious Email Attachment' involving user002@orionbank.example / WKS-134 and source 203.0.113.15.
09:03	Normalize	SOAR creates SOAR-002, stores raw event, extracts IP 203.0.113.15, domain case002-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.15 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.23 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-002.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.

- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-003 - Business Email Compromise / Payment Fraud

Domain: Email & Collaboration

Objective	Stop fraudulent payment or sensitive-information requests caused by impersonation or compromised mailboxes.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	High-risk payment request, vendor bank-detail change, executive impersonation, or abnormal mailbox behavior.
ATT&CK v19.2 mapping	T1566 Phishing; T1656 Impersonation; T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- High-risk payment request, vendor bank-detail change, executive impersonation, or abnormal mailbox behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-003. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: High-risk payment request, vendor bank-detail change, executive impersonation, or abnormal mailbox behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
6. Preserve evidence	for the classification. Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-003_BUSINESS_EMAIL_COMPROMISE_PAYMENT_FRAUD
ON: alert where rule_family == "BUSINESS_EMAIL_COMPROMISE_PAYMENT_FRAUD"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)

```

```

IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Business Email Compromise / Payment Fraud. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Business Email Compromise / Payment Fraud' involving user003@orionbank.example / WKS-151 and source 203.0.113.22.
09:03	Normalize	SOAR creates SOAR-003, stores raw event, extracts IP 203.0.113.22, domain case003-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.22 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.34 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-003.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-004 - QR Code Phishing

Domain: Email & Collaboration

Objective	Detect QR-based phishing that bypasses normal URL inspection and leads users to credential theft or malicious sites.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Email/document contains QR code tied to suspicious destination, or user reports scan-to-login lure.
ATT&CK v19.2 mapping	T1566 Phishing; T1204.001 User Execution: Malicious Link
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment

	follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Email/document contains QR code tied to suspicious destination, or user reports scan-to-login lure.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-004. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Email/document contains QR code tied to suspicious destination, or user reports scan-to-login lure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts,	Remediation tasks completed/assigned

Step	SOAR / Analyst Action	Expected Output
	patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-004_QR_CODE_PHISHING
ON: alert where rule_family == "QR_CODE_PHISHING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for QR Code Phishing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'QR Code Phishing' involving user004@orionbank.example / WKS-168 and source 203.0.113.29.
09:03	Normalize	SOAR creates SOAR-004, stores raw event,

Time	Stage	Simulation
		extracts IP 203.0.113.29, domain case004-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.29 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.45 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-004.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-005 - AiTM Phishing and Session Token Theft

Domain: Email & Collaboration

Objective	Contain adversary-in-the-middle phishing that captures credentials, MFA sessions, cookies, or tokens.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Suspicious reverse-proxy phishing, token replay, abnormal session reuse, or post-MFA sign-in from attacker infrastructure.
ATT&CK v19.2 mapping	T1557 Adversary-in-the-Middle; T1539 Steal Web Session Cookie; T1528 Steal Application Access Token
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Suspicious reverse-proxy phishing, token replay, abnormal session reuse, or post-MFA sign-in from attacker infrastructure.

- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-005. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Suspicious reverse-proxy phishing, token replay, abnormal session reuse, or post-MFA sign-in from attacker infrastructure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.

- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-005_AITM_PHISHING_AND_SESSION_TOKEN_THEFT
ON: alert where rule_family == "AITM_PHISHING_AND_SESSION_TOKEN_THEFT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for AiTM Phishing and Session Token Theft. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'AiTM Phishing and Session Token Theft' involving user005@orionbank.example / WKS-185 and source 203.0.113.36.
09:03	Normalize	SOAR creates SOAR-005, stores raw event, extracts IP 203.0.113.36, domain case005-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.36 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.56 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-005.

Time	Stage	Simulation
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-006 - Device Code Phishing / OAuth Token Capture

Domain: Email & Collaboration

Objective	Respond to device-code phishing that tricks users into authorizing attacker-controlled sessions.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Unusual device-code authentication, unexpected OAuth authorization, or user reports being asked to enter a device code.
ATT&CK v19.2 mapping	T1528 Steal Application Access Token; T1204.004 User Execution: Malicious Copy and Paste; T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Unusual device-code authentication, unexpected OAuth authorization, or user reports being asked to enter a device code.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-006. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add	Criticality/reputation/context fields

Step	SOAR / Analyst Action	Expected Output
	business criticality, owner, privileged status, exposure, reputation and recent related detections.	
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Unusual device-code authentication, unexpected OAuth authorization, or user reports being asked to enter a device code. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-006_DEVICE_CODE_PHISHING_OAUTH_TOKEN_CAPTURE
ON: alert where rule_family == "DEVICE_CODE_PHISHING_OAUTH_TOKEN_CAPTURE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Device Code Phishing / OAuth Token Capture. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Device Code Phishing / OAuth Token Capture' involving user006@orionbank.example / WKS-202 and source 203.0.113.43.
09:03	Normalize	SOAR creates SOAR-006, stores raw event, extracts IP 203.0.113.43, domain case006-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.43 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.67 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-006.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-007 - ClickFix / Malicious Copy-Paste Execution

Domain: Email & Collaboration

Objective	Detect social engineering that instructs a user to paste attacker-controlled commands into Run, PowerShell, Terminal, or shell.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Browser/email lure followed by suspicious shell execution, clipboard-driven command, or user report of fake CAPTCHA/fix prompt.
ATT&CK v19.2 mapping	T1204.004 User Execution: Malicious Copy and Paste; T1059 Command and Scripting Interpreter
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Browser/email lure followed by suspicious shell execution, clipboard-driven command, or user report of fake CAPTCHA/fix prompt.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-007. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Browser/email lure followed by suspicious shell execution, clipboard-driven command, or user report of fake CAPTCHA/fix prompt. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and	Approved/denied/conditional action plan

Step	SOAR / Analyst Action	Expected Output
	business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-007_CLICKFIX_MALICIOUS_COPY_PASTE_EXECUTION
ON: alert where rule_family == "CLICKFIX_MALICIOUS_COPY_PASTE_EXECUTION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for ClickFix / Malicious Copy-Paste Execution. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'ClickFix / Malicious Copy-Paste Execution' involving user007@orionbank.example / WKS-219 and source 203.0.113.50.
09:03	Normalize	SOAR creates SOAR-007, stores raw event, extracts IP 203.0.113.50, domain case007-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.50 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.78 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-007.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-008 - MFA Fatigue / Push Bombing

Domain: Email & Collaboration

Objective	Stop repeated MFA prompts intended to coerce users into approving attacker access.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Burst of denied MFA pushes, repeated authentication attempts, or user reports unsolicited MFA prompts.
ATT&CK v19.2 mapping	T1621 Multi-Factor Authentication Request Generation; T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Burst of denied MFA pushes, repeated authentication attempts, or user reports unsolicited MFA prompts.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-008. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Burst of denied MFA pushes, repeated authentication attempts, or user reports unsolicited MFA prompts. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-008_MFA_FATIGUE_PUSH_BOMBING
ON: alert where rule_family == "MFA_FATIGUE_PUSH_BOMBING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for MFA Fatigue / Push Bombing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'MFA Fatigue / Push Bombing' involving user008@orionbank.example / WKS-236 and source 203.0.113.57.
09:03	Normalize	SOAR creates SOAR-008, stores raw event, extracts IP 203.0.113.57, domain case008-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.57 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.89 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity

Time	Stage	Simulation
		exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-008.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-009 - OAuth Consent Phishing

Domain: Email & Collaboration

Objective	Remove malicious application consent and revoke access granted to attacker-controlled OAuth applications.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New consent grant to risky app, excessive permissions, unusual publisher, or user reports consent screen.
ATT&CK v19.2 mapping	T1528 Steal Application Access Token; T1098 Account Manipulation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New consent grant to risky app, excessive permissions, unusual publisher, or user reports consent screen.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-009. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
2. Deduplicate and correlate	payload. Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New consent grant to risky app, excessive permissions, unusual publisher, or user reports consent screen. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
----------------------------	--------------------------

initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-009_OAUTH_CONSENT_PHISHING
ON: alert where rule_family == "OAUTH_CONSENT_PHISHING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for OAuth Consent Phishing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'OAuth Consent Phishing' involving user009@orionbank.example / WKS-253 and source 203.0.113.64.
09:03	Normalize	SOAR creates SOAR-009, stores raw event, extracts IP 203.0.113.64, domain case009-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.64 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.100 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-009.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.

- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-010 - Suspicious Inbox Rule

Domain: Email & Collaboration

Objective	Detect and remove attacker-created mailbox rules that hide messages, redirect mail, or support BEC persistence.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New/modified rule deletes security alerts, moves finance mail, or uses suspicious forwarding/actions.
ATT&CK v19.2 mapping	T1564.008 Hide Artifacts: Email Hiding Rules; T1114 Email Collection
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New/modified rule deletes security alerts, moves finance mail, or uses suspicious forwarding/actions.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-010. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New/modified rule deletes security alerts, moves finance mail, or uses suspicious forwarding/actions. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the	Evidence package references

Step	SOAR / Analyst Action	Expected Output
7. Run scoped hunt	case with timestamps and source system. Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-010_SUSPICIOUS_INBOX_RULE
ON: alert where rule_family == "SUSPICIOUS_INBOX_RULE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()

```

```

    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Suspicious Inbox Rule. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Suspicious Inbox Rule' involving user010@orionbank.example / WKS-270 and source 203.0.113.71.
09:03	Normalize	SOAR creates SOAR-010, stores raw event, extracts IP 203.0.113.71, domain case010-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.71 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.111 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-010.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-011 - Unauthorized Mailbox Forwarding

Domain: Email & Collaboration

Objective	Stop external forwarding that leaks mail or maintains attacker visibility.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Mailbox forwarding or transport rule sends mail to an unapproved external address.
ATT&CK v19.2 mapping	T1114 Email Collection; T1020 Automated Exfiltration
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Mailbox forwarding or transport rule sends mail to an unapproved external address.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-011. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Mailbox forwarding or transport rule sends mail to an unapproved external address. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
	least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-011_UNAUTHORIZED_MAILBOX_FORWARDING
ON: alert where rule_family == "UNAUTHORIZED_MAILBOX_FORWARDING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Unauthorized Mailbox Forwarding. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Unauthorized Mailbox Forwarding' involving user011@orionbank.example / WKS-287 and source 203.0.113.78.
09:03	Normalize	SOAR creates SOAR-011, stores raw event, extracts IP 203.0.113.78, domain case011-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.78 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.122 and links them to the same case. Risk score

Time	Stage	Simulation
09:07	Validation	increases to 66/100. Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-011.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-012 - Internal Account Sending Phish

Domain: Email & Collaboration

Objective	Contain a compromised internal mailbox being used to send phishing or malicious files to colleagues/partners.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Internal account suddenly sends high-volume or unusual phishing-like messages.
ATT&CK v19.2 mapping	T1078 Valid Accounts; T1566 Phishing
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Internal account suddenly sends high-volume or unusual phishing-like messages.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-012. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Internal account suddenly sends high-volume or unusual phishing-like messages. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.

- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-012_INTERNAL_ACCOUNT_SENDING_PHISH
ON: alert where rule_family == "INTERNAL_ACCOUNT_SENDING_PHISH"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Internal Account Sending Phish. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Internal Account Sending Phish' involving user012@orionbank.example / WKS-304 and source 203.0.113.85.
09:03	Normalize	SOAR creates SOAR-012, stores raw event, extracts IP 203.0.113.85, domain case012-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.85 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.133 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-012.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-013 - Executive Impersonation / Display Name Spoofing

Domain: Email & Collaboration

Objective	Detect and suppress impersonation of executives, finance staff, vendors, or other high-risk identities.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Display-name/domain similarity, reply-to mismatch, or high-risk request from external sender.
ATT&CK v19.2 mapping	T1656 Impersonation; T1566 Phishing
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Display-name/domain similarity, reply-to mismatch, or high-risk request from external sender.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-013. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Display-	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	name/domain similarity, reply-to mismatch, or high-risk request from external sender. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-013_EXECUTIVE_IMPERSONATION_DISPLAY_NAME_SPOOFING
ON: alert where rule_family == "EXECUTIVE_IMPERSONATION_DISPLAY_NAME_SPOOFING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)

```

```

enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Executive Impersonation / Display Name Spoofing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Executive Impersonation / Display Name Spoofing' involving user013@orionbank.example / WKS-321 and source 203.0.113.92.
09:03	Normalize	SOAR creates SOAR-013, stores raw event, extracts IP 203.0.113.92, domain case013-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.92 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.144 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-013.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-014 - Email Bombing / Helpdesk Social Engineering

Domain: Email & Collaboration

Objective	Identify email-bombing used to distract users and enable vishing/helpdesk social engineering or MFA reset attacks.
------------------	--

Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Sudden subscription flood or message burst coincides with helpdesk contact, password/MFA reset, or suspicious sign-ins.
ATT&CK v19.2 mapping	T1498 Network Denial of Service (supporting distraction); T1684.001 Social Engineering: Impersonation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Sudden subscription flood or message burst coincides with helpdesk contact, password/MFA reset, or suspicious sign-ins.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-014. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Sudden subscription flood or message burst coincides with helpdesk contact, password/MFA reset, or suspicious sign-ins. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high,	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-014_EMAIL_BOMBING_HELPDESK_SOCIAL_ENGINEERING
ON: alert where rule_family == "EMAIL_BOMBING_HELPDESK_SOCIAL_ENGINEERING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Email Bombing / Helpdesk Social Engineering. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Email Bombing / Helpdesk Social Engineering' involving user014@orionbank.example / WKS-338 and source 203.0.113.99.
09:03	Normalize	SOAR creates SOAR-014, stores raw event, extracts IP 203.0.113.99, domain case014-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.99 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.155 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-014.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-015 - Malicious SharePoint / OneDrive / Teams File Share

Domain: Email & Collaboration

Objective	Contain malicious links or files distributed through trusted collaboration platforms.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	External/internal share includes suspicious file/link, sandbox hit, or recipient execution is observed.
ATT&CK v19.2 mapping	T1566 Phishing; T1102 Web Service; T1204 User Execution
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Email gateway/message trace: sender, recipient, subject, Message-ID, delivery status, URLs, attachment hashes
- M365/Google Workspace audit: sign-ins, mailbox rules, forwarding, consent, file-share events
- URL/file sandbox and threat-intelligence enrichment
- Identity-provider risk, MFA, session and token telemetry
- Endpoint telemetry for click/open/execution confirmation

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- External/internal share includes suspicious file/link, sandbox hit, or recipient execution is observed.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-015. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: External/internal share includes suspicious file/link, sandbox hit, or recipient execution is observed. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated. Specific actions: search-and-purge related messages across recipients; extract and detonate URLs/attachments; review recipient click/open and sign-in activity.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If any recipient clicked/opened/executed, branch to identity and endpoint containment; if no interaction occurred and the message was removed, close as prevented/attempt after validation.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-015_MALICIOUS_SHAREPOINT_ONEDRIVE_TEAMS_FILE_SHARE
ON: alert where rule_family == "MALICIOUS_SHAREPOINT_ONEDRIVE_TEAMS_FILE_SHARE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Malicious SharePoint / OneDrive / Teams File Share. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Malicious SharePoint / OneDrive / Teams File Share' involving user015@orionbank.example / WKS-355 and source 203.0.113.106.
09:03	Normalize	SOAR creates SOAR-015, stores raw event, extracts IP 203.0.113.106, domain case015-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.106 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.166 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity

Time	Stage	Simulation
		exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Quarantine/remove malicious messages, block sender/domain/URL/hash where confidence is high, revoke affected sessions, and isolate endpoints only when execution or endpoint compromise is indicated.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-015.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-016 - Password Spray

Domain: Identity & Active Directory

Objective	Detect low-and-slow authentication attempts against many users and block the source before compromise.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Many usernames receive failed logons from a small set of sources with low attempts per account.
ATT&CK v19.2 mapping	T1110.003 Brute Force: Password Spraying
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Many usernames receive failed logons from a small set of sources with low attempts per account.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-016. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Many usernames receive failed logons from a small set of sources with low attempts per account. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats

approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-016_PASSWORD_SPRAY
ON: alert where rule_family == "PASSWORD_SPRAY"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Password Spray. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Password Spray' involving user016@orionbank.example / WKS-372 and source 203.0.113.113.
09:03	Normalize	SOAR creates SOAR-016, stores raw event, extracts IP 203.0.113.113, domain case016-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.113 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.177 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-016.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.

- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-017 - Credential Stuffing

Domain: Identity & Active Directory

Objective	Stop automated reuse of stolen username/password pairs across exposed services.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	High-volume login attempts using many username/password combinations, often from distributed infrastructure.
ATT&CK v19.2 mapping	T1110.004 Brute Force: Credential Stuffing
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- High-volume login attempts using many username/password combinations, often from distributed infrastructure.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-017. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: High-volume login attempts using many username/password combinations, often from distributed infrastructure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references

Step	SOAR / Analyst Action	Expected Output
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-017_CREDENTIAL_STUFFING
ON: alert where rule_family == "CREDENTIAL_STUFFING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()

```

```

        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Credential Stuffing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Credential Stuffing' involving user017@orionbank.example / WKS-389 and source 203.0.113.120.
09:03	Normalize	SOAR creates SOAR-017, stores raw event, extracts IP 203.0.113.120, domain case017-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.120 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.188 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-017.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-018 - Impossible Travel / Anomalous Sign-In

Domain: Identity & Active Directory

Objective	Validate geographically or behaviorally impossible sign-ins and contain compromised sessions.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Two successful sign-ins are inconsistent with normal travel, device, ASN, or user behavior.
ATT&CK v19.2 mapping	T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Two successful sign-ins are inconsistent with normal travel, device, ASN, or user behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-018. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Two successful sign-ins are inconsistent with normal travel, device, ASN, or user behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
	after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-018_IMPOSSIBLE_TRAVEL_ANOMALOUS_SIGN_IN
ON: alert where rule_family == "IMPOSSIBLE_TRAVEL_ANOMALOUS_SIGN_IN"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Impossible Travel / Anomalous Sign-In. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Impossible Travel / Anomalous Sign-In' involving user018@orionbank.example / WKS-406 and source 203.0.113.127.
09:03	Normalize	SOAR creates SOAR-018, stores raw event, extracts IP 203.0.113.127, domain case018-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.127 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is

Time	Stage	Simulation
09:05	Correlation	found. SOAR finds two related events from 198.51.100.199 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-018.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-019 - Risky User / Unfamiliar Sign-In

Domain: Identity & Active Directory

Objective	Triage identity-provider risk detections and determine whether an account is compromised.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Identity risk engine flags unfamiliar sign-in properties, anonymous IP, malware-linked IP, or atypical token behavior.
ATT&CK v19.2 mapping	T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Identity risk engine flags unfamiliar sign-in properties, anonymous IP, malware-linked IP, or atypical token behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-019. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Identity risk engine flags unfamiliar sign-in properties, anonymous IP, malware-linked IP, or atypical token behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.

- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-019_RISKY_USER_UNFAMILIAR_SIGN_IN
ON: alert where rule_family == "RISKY_USER_UNFAMILIAR_SIGN_IN"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Risky User / Unfamiliar Sign-In. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Risky User / Unfamiliar Sign-In' involving user019@orionbank.example / WKS-423 and source 203.0.113.134.
09:03	Normalize	SOAR creates SOAR-019, stores raw event, extracts IP 203.0.113.134, domain case019-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.134 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.210 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-019.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-020 - Privileged Account Compromise

Domain: Identity & Active Directory

Objective	Rapidly contain suspected compromise of administrator or high-impact privileged accounts.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Risky sign-in, abnormal admin action, credential theft indicator, or user report affects privileged identity.
ATT&CK v19.2 mapping	T1078.002 Valid Accounts: Domain Accounts; T1098 Account Manipulation
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Risky sign-in, abnormal admin action, credential theft indicator, or user report affects privileged identity.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-020. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Risky	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	sign-in, abnormal admin action, credential theft indicator, or user report affects privileged identity. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-020_PRIVILEGED_ACCOUNT_COMPROMISE
ON: alert where rule_family == "PRIVILEGED_ACCOUNT_COMPROMISE"
DO:

```



```

normalize(alert)
case = dedupe_or_create(correlation_key, window=60m)
enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Privileged Account Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Privileged Account Compromise' involving user020@orionbank.example / WKS-440 and source 203.0.113.141.
09:03	Normalize	SOAR creates SOAR-020, stores raw event, extracts IP 203.0.113.141, domain case020-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.141 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.221 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-020.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-021 - Break-Glass Account Use

Domain: Identity & Active Directory

Objective	Validate emergency-account usage and escalate any unplanned use as a critical identity event.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Emergency/break-glass account authenticates or changes configuration outside approved test/incident window.
ATT&CK v19.2 mapping	T1078 Valid Accounts
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Emergency/break-glass account authenticates or changes configuration outside approved test/incident window.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-021. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Emergency/break-glass account authenticates or changes configuration outside approved test/incident window. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-021_BREAK_GLASS_ACCOUNT_USE
ON: alert where rule_family == "BREAK_GLASS_ACCOUNT_USE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Break-Glass Account Use. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Break-Glass Account Use' involving user021@orionbank.example / WKS-457 and source 203.0.113.148.
09:03	Normalize	SOAR creates SOAR-021, stores raw event, extracts IP 203.0.113.148, domain case021-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.148 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.232 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-021.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-022 - Service Account / Non-Human Identity Compromise

Domain: Identity & Active Directory

Objective	Contain suspected compromise of service accounts without causing uncontrolled service outages.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Service/NHI account authenticates from new host, interactive session, unusual time, or changes privilege/secret use pattern.
ATT&CK v19.2 mapping	T1078 Valid Accounts; T1552 Unsecured Credentials
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Service/NHI account authenticates from new host, interactive session, unusual time, or changes privilege/secret use pattern.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-022. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Service/NHI account authenticates from new host, interactive session, unusual time, or changes privilege/secret use pattern. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence,	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-022_SERVICE_ACCOUNT_NON_HUMAN_IDENTITY_COMPROMISE
ON: alert where rule_family == "SERVICE_ACCOUNT_NON_HUMAN_IDENTITY_COMPROMISE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Service Account / Non-Human Identity Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Service Account / Non-Human Identity Compromise' involving user022@orionbank.example / WKS-474 and source 203.0.113.155.
09:03	Normalize	SOAR creates SOAR-022, stores raw event, extracts IP 203.0.113.155, domain case022-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.155 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.243 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.

Time	Stage	Simulation
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-022.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-023 - Secret / API Key Exposure

Domain: Identity & Active Directory

Objective	Rotate exposed secrets quickly and determine whether they were used before revocation.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Secret scanner, code repository, DLP, paste-site, or CTI feed identifies an exposed credential/key/token.
ATT&CK v19.2 mapping	T1552 Unsecured Credentials
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Secret scanner, code repository, DLP, paste-site, or CTI feed identifies an exposed credential/key/token.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-023. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
	raw-event references. Preserve the original alert payload.	
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Secret scanner, code repository, DLP, paste-site, or CTI feed identifies an exposed credential/key/token. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-023_SECRET_API_KEY_EXPOSURE
ON: alert where rule_family == "SECRET_API_KEY_EXPOSURE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Secret / API Key Exposure. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Secret / API Key Exposure' involving user023@orionbank.example / WKS-491 and source 203.0.113.162.
09:03	Normalize	SOAR creates SOAR-023, stores raw event, extracts IP 203.0.113.162, domain case023-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.162 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.4 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-023.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.

- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-024 - New MFA Method Registration

Domain: Identity & Active Directory

Objective	Detect attacker persistence through unauthorized MFA method registration or authentication-method change.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New phone, passkey, authenticator, FIDO key, or recovery method is added under suspicious circumstances.
ATT&CK v19.2 mapping	T1098.005 Account Manipulation: Device Registration
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New phone, passkey, authenticator, FIDO key, or recovery method is added under suspicious circumstances.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-024. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New phone, passkey, authenticator, FIDO key, or recovery method is added under suspicious circumstances. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
6. Preserve evidence	for the classification. Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-024_NEW_MFA_METHOD_REGISTRATION
ON: alert where rule_family == "NEW_MFA_METHOD_REGISTRATION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)

```

```

hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for New MFA Method Registration. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'New MFA Method Registration' involving user024@orionbank.example / WKS-508 and source 203.0.113.169.
09:03	Normalize	SOAR creates SOAR-024, stores raw event, extracts IP 203.0.113.169, domain case024-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.169 as suspicious; CMDb marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.15 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-024.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-025 - Privileged Role Assignment

Domain: Identity & Active Directory

Objective	Validate and reverse unauthorized elevation to admin, directory, cloud, or application roles.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	New privileged role assignment or group membership occurs outside approved change process.
ATT&CK v19.2 mapping	T1098 Account Manipulation; T1548 Abuse Elevation Control Mechanism

Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New privileged role assignment or group membership occurs outside approved change process.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-025. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New privileged role assignment or group membership occurs outside approved change process. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
10. Eradicate root cause	radius. Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-025_PRIVILEGED_ROLE_ASSIGNMENT
ON: alert where rule_family == "PRIVILEGED_ROLE_ASSIGNMENT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Privileged Role Assignment. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Privileged Role Assignment' involving user025@orionbank.example / WKS-525

Time	Stage	Simulation
		and source 203.0.113.176.
09:03	Normalize	SOAR creates SOAR-025, stores raw event, extracts IP 203.0.113.176, domain case025-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.176 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.26 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-025.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-026 - Account Creation + Privilege Escalation

Domain: Identity & Active Directory

Objective	Detect attacker-created accounts and subsequent privilege assignment or persistence.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New account is followed by sensitive group/role membership, remote logon, or resource access.
ATT&CK v19.2 mapping	T1136 Create Account; T1098 Account Manipulation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New account is followed by sensitive group/role membership, remote logon, or resource access.

- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-026. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New account is followed by sensitive group/role membership, remote logon, or resource access. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.

- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-026_ACCOUNT_CREATION_PRIVILEGE_ESCALATION
ON: alert where rule_family == "ACCOUNT_CREATION_PRIVILEGE_ESCALATION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Account Creation + Privilege Escalation. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Account Creation + Privilege Escalation' involving user026@orionbank.example / WKS-542 and source 203.0.113.183.
09:03	Normalize	SOAR creates SOAR-026, stores raw event, extracts IP 203.0.113.183, domain case026-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.183 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.37 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-026.

Time	Stage	Simulation
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-027 - Kerberoasting

Domain: Identity & Active Directory

Objective	Detect suspicious service-ticket requests used to obtain offline crackable service-account material.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Unusual volume/pattern of Kerberos service ticket requests targets SPNs, especially high-value service accounts.
ATT&CK v19.2 mapping	T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Unusual volume/pattern of Kerberos service ticket requests targets SPNs, especially high-value service accounts.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-027. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status,	Criticality/reputation/context fields

Step	SOAR / Analyst Action	Expected Output
4. Score risk	exposure, reputation and recent related detections. Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Unusual volume/pattern of Kerberos service ticket requests targets SPNs, especially high-value service accounts. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-027_KERBEROASTING
ON: alert where rule_family == "KERBEROASTING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Kerberoasting. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Kerberoasting' involving user027@orionbank.example / WKS-559 and source 203.0.113.190.
09:03	Normalize	SOAR creates SOAR-027, stores raw event, extracts IP 203.0.113.190, domain case027-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.190 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.48 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-027.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-028 - DCSync

Domain: Identity & Active Directory

Objective	Detect replication abuse used to extract password hashes from Active Directory.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Non-domain-controller host/account requests directory replication privileges or DRS replication operations.
ATT&CK v19.2 mapping	T1003.006 OS Credential Dumping: DCSync
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Non-domain-controller host/account requests directory replication privileges or DRS replication operations.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-028. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Non-domain-controller host/account requests directory replication privileges or DRS replication operations. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows	Approved/denied/conditional action plan

Step	SOAR / Analyst Action	Expected Output
	confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-028_DCSYNC
ON: alert where rule_family == "DCSYNC"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")

```

never_mark_closed_on_action_failure

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for DCSync. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'DCSync' involving user028@orionbank.example / WKS-576 and source 203.0.113.197.
09:03	Normalize	SOAR creates SOAR-028, stores raw event, extracts IP 203.0.113.197, domain case028-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.197 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.59 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-028.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-029 - Golden / Silver Ticket Indicators

Domain: Identity & Active Directory

Objective	Detect forged Kerberos ticket use and coordinate domain credential recovery.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Impossible ticket lifetimes, SID anomalies, abnormal service access, or post-compromise Kerberos indicators.
ATT&CK v19.2 mapping	T1558.001 Golden Ticket; T1558.002 Silver Ticket
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes

- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Impossible ticket lifetimes, SID anomalies, abnormal service access, or post-compromise Kerberos indicators.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-029. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Impossible ticket lifetimes, SID anomalies, abnormal service access, or post-compromise Kerberos indicators. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence,	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minute	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-029_GOLDEN_SILVER_TICKET_INDICATORS
ON: alert where rule_family == "GOLDEN_SILVER_TICKET_INDICATORS"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Golden / Silver Ticket Indicators. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Golden / Silver Ticket Indicators' involving user029@orionbank.example / WKS-593 and source 203.0.113.204.
09:03	Normalize	SOAR creates SOAR-029, stores raw event, extracts IP 203.0.113.204, domain case029-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.204 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.70 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity

Time	Stage	Simulation
		exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-029.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-030 - AD Group / GPO Tampering

Domain: Identity & Active Directory

Objective	Stop malicious changes to privileged groups, GPOs, scripts, or directory security settings.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Critical AD group membership, GPO, logon script, or policy object changes outside approved change.
ATT&CK v19.2 mapping	T1484.001 Domain or Tenant Policy Modification: Group Policy Modification; T1098 Account Manipulation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Identity-provider sign-in and risk logs; MFA/authentication-method events
- Active Directory/LDAP/Kerberos security events and privileged-group changes
- PAM/PIM and privileged role-assignment telemetry
- CMDB/HR/identity owner and criticality attributes
- Endpoint/network telemetry for source device and post-authentication activity

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Critical AD group membership, GPO, logon script, or policy object changes outside approved change.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-030. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
2. Deduplicate and correlate	payload. Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Critical AD group membership, GPO, logon script, or policy object changes outside approved change. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If a successful suspicious authentication or privilege change is confirmed, revoke sessions and reset/rotate credentials; failed-only activity can remain an attempted attack if no downstream access is found.

5. Recommended SOAR Variables

correlation_window_minute	60 (adjust for use case)
----------------------------------	--------------------------

s	
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-030_AD_GROUP_GPO_TAMPERING
ON: alert where rule_family == "AD_GROUP_GPO_TAMPERING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for AD Group / GPO Tampering. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'AD Group / GPO Tampering' involving user030@orionbank.example / WKS-610 and source 203.0.113.211.
09:03	Normalize	SOAR creates SOAR-030, stores raw event, extracts IP 203.0.113.211, domain case030-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.211 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.81 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/tokens, reset or rotate credentials, disable or restrict the identity when risk remains active, remove unauthorized MFA/role/group changes, and protect break-glass/service identities with approval gates.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-030.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.

- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-031 - Endpoint Malware Detection

Domain: Endpoint & Malware

Objective	Automate malware triage, isolation, IOC sweep, and recovery while preserving evidence.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	EDR/AV detects malicious file/process or high-confidence behavioral malware alert.
ATT&CK v19.2 mapping	T1204 User Execution; T1105 Ingress Tool Transfer
Automation posture	Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- EDR/AV detects malicious file/process or high-confidence behavioral malware alert.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-031. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: EDR/AV detects malicious file/process or high-confidence behavioral malware alert. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree,	Evidence package references

Step	SOAR / Analyst Action	Expected Output
	authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-031_ENDPOINT_MALWARE_DETECTION
ON: alert where rule_family == "ENDPOINT_MALWARE_DETECTION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:

```



```

IF score >= 85 AND not critical_exception:
    execute_guarded_containment()
ELSE:
    request_analyst_decision()
    eradicate_root_cause()
    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Endpoint Malware Detection. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Endpoint Malware Detection' involving user031@orionbank.example / WKS-627 and source 203.0.113.218.
09:03	Normalize	SOAR creates SOAR-031, stores raw event, extracts IP 203.0.113.218, domain case031-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.218 as suspicious; CMDb marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.92 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-031.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-032 - Ransomware Precursors

Domain: Endpoint & Malware

Objective	Identify and interrupt pre-encryption behaviors such as credential theft, backup discovery, mass file access, and defense impairment.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	EDR/SIEM correlation detects multiple ransomware precursor behaviors on one identity/host.
ATT&CK v19.2 mapping	T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery; T1562 Impair Defenses
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.

Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.
-----------------------------	---

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- EDR/SIEM correlation detects multiple ransomware precursor behaviors on one identity/host.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-032. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: EDR/SIEM correlation detects multiple ransomware precursor behaviors on one identity/host. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized	Remediation tasks completed/assigned

Step	SOAR / Analyst Action	Expected Output
	permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-032_RANSOMWARE_PRECURSORS
ON: alert where rule_family == "RANSOMWARE_PRECURSORS"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Ransomware Precursors. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Ransomware Precursors' involving user032@orionbank.example / WKS-644 and source 203.0.113.225.
09:03	Normalize	SOAR creates SOAR-032, stores raw event, extracts IP 203.0.113.225, domain case032-verify.example and relevant entity identifiers.

Time	Stage	Simulation
09:04	Enrichment	Threat intelligence scores 203.0.113.225 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.103 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-032.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-033 - Active Ransomware Encryption

Domain: Endpoint & Malware

Objective	Immediately contain active encryption, stop propagation, protect backups, and invoke major incident response.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Canary file changes, mass extension changes, encryption behavior, ransom note, or EDR ransomware verdict.
ATT&CK v19.2 mapping	T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery
Automation posture	Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Canary file changes, mass extension changes, encryption behavior, ransom note, or EDR ransomware verdict.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.

- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-033. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Canary file changes, mass extension changes, encryption behavior, ransom note, or EDR ransomware verdict. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.

- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-033_ACTIVE_RANSOMWARE_ENCRYPTION
ON: alert where rule_family == "ACTIVE_RANSOMWARE_ENCRYPTION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Active Ransomware Encryption. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Active Ransomware Encryption' involving user033@orionbank.example / WKS-661 and source 203.0.113.232.
09:03	Normalize	SOAR creates SOAR-033, stores raw event, extracts IP 203.0.113.232, domain case033-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.232 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.114 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-033.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-

Time	Stage	Simulation
		up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-034 - Data Wiper / Destructive Attack

Domain: Endpoint & Malware

Objective	Stop destructive activity that deletes files, partitions, backups, or critical configurations.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	EDR/storage telemetry indicates mass deletion, destructive utilities, disk overwrite, or tampering with recovery assets.
ATT&CK v19.2 mapping	T1485 Data Destruction; T1561 Disk Wipe
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- EDR/storage telemetry indicates mass deletion, destructive utilities, disk overwrite, or tampering with recovery assets.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-034. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical;	Risk score + severity

Step	SOAR / Analyst Action	Expected Output
	automatically raise one level for privileged identities or critical production assets.	
5. Validate the trigger	Test the core hypothesis for this use case: EDR/storage telemetry indicates mass deletion, destructive utilities, disk overwrite, or tampering with recovery assets. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-034_DATA_WIPER_DESTRUCTIVE_ATTACK
ON: alert where rule_family == "DATA_WIPER_DESTRUCTIVE_ATTACK"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Data Wiper / Destructive Attack. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Data Wiper / Destructive Attack' involving user034@orionbank.example / WKS-678 and source 203.0.113.239.
09:03	Normalize	SOAR creates SOAR-034, stores raw event, extracts IP 203.0.113.239, domain case034-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.239 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.125 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-034.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-035 - Suspicious PowerShell

Domain: Endpoint & Malware

Objective	Triage suspicious PowerShell use and contain malicious scripting without disrupting legitimate administration.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	PowerShell runs encoded/download/credential commands, hidden windows, unusual parent process, or suspicious network call.
ATT&CK v19.2 mapping	T1059.001 PowerShell
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- PowerShell runs encoded/download/credential commands, hidden windows, unusual parent process, or suspicious network call.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-035. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: PowerShell runs encoded/download/credential commands, hidden windows, unusual parent process, or suspicious network call. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response:	Approved/denied/conditional action plan

Step	SOAR / Analyst Action	Expected Output
	enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-035_SUSPICIOUS_POWERSHELL
ON: alert where rule_family == "SUSPICIOUS_POWERSHELL"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")

```

never_mark_closed_on_action_failure

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Suspicious PowerShell. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Suspicious PowerShell' involving user035@orionbank.example / WKS-695 and source 203.0.113.246.
09:03	Normalize	SOAR creates SOAR-035, stores raw event, extracts IP 203.0.113.246, domain case035-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.246 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.136 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-035.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-036 - Encoded / Obfuscated Command

Domain: Endpoint & Malware

Objective	Decode and evaluate obfuscated command lines, then contain malicious execution.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Command-line telemetry contains Base64/obfuscation, excessive escaping, compressed script, or suspicious decoder chain.
ATT&CK v19.2 mapping	T1027 Obfuscated Files or Information; T1140 Deobfuscate/Decode Files or Information
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation

- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Command-line telemetry contains Base64/obfuscation, excessive escaping, compressed script, or suspicious decoder chain.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-036. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Command-line telemetry contains Base64/obfuscation, excessive escaping, compressed script, or suspicious decoder chain. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
12. Close and improve	requires longer. Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-036_ENCODED_OBFUSCATED_COMMAND
ON: alert where rule_family == "ENCODED_OBFUSCATED_COMMAND"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Encoded / Obfuscated Command. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Encoded / Obfuscated Command' involving user036@orionbank.example / WKS-712 and source 203.0.113.3.
09:03	Normalize	SOAR creates SOAR-036, stores raw event, extracts IP 203.0.113.3, domain case036-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.3 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.147 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook

Time	Stage	Simulation
		hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-036.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-037 - LOLBin Abuse

Domain: Endpoint & Malware

Objective	Detect abuse of signed/native binaries used to proxy execution, download payloads, or bypass controls.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Native utility such as mshta, rundll32, regsvr32, certutil, or similar exhibits suspicious behavior.
ATT&CK v19.2 mapping	T1218 System Binary Proxy Execution
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Native utility such as mshta, rundll32, regsvr32, certutil, or similar exhibits suspicious behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-037. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP,	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
	URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Native utility such as mshta, rundll32, regsvr32, certutil, or similar exhibits suspicious behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-037_LOLBIN_ABUSE
ON: alert where rule_family == "LOLBIN_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for LOLBin Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'LOLBin Abuse' involving user037@orionbank.example / WKS-729 and source 203.0.113.10.
09:03	Normalize	SOAR creates SOAR-037, stores raw event, extracts IP 203.0.113.10, domain case037-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.10 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.158 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-037.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.

- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-038 - Credential Dumping / LSASS Access

Domain: Endpoint & Malware

Objective	Stop credential theft from LSASS, SAM, security authority, browser, or local credential stores.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	EDR detects suspicious process access to LSASS or known credential-dumping patterns.
ATT&CK v19.2 mapping	T1003 OS Credential Dumping
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- EDR detects suspicious process access to LSASS or known credential-dumping patterns.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-038. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: EDR detects suspicious process access to LSASS or known credential-dumping patterns. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
6. Preserve evidence	classification. Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-038_CREDENTIAL_DUMPING_LSASS_ACCESS
ON: alert where rule_family == "CREDENTIAL_DUMPING_LSASS_ACCESS"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)

```

```

IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Credential Dumping / LSASS Access. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Credential Dumping / LSASS Access' involving user038@orionbank.example / WKS-746 and source 203.0.113.17.
09:03	Normalize	SOAR creates SOAR-038, stores raw event, extracts IP 203.0.113.17, domain case038-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.17 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.169 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-038.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-039 - EDR Tampering / Disabled

Domain: Endpoint & Malware

Objective	Restore endpoint visibility and isolate systems where EDR is disabled, uninstalled, or tampered with.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Sensor health alert, policy disable, service stop, tamper event, or missing heartbeat on critical host.
ATT&CK v19.2 mapping	T1562.001 Impair Defenses: Disable or Modify Tools
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment

	follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Sensor health alert, policy disable, service stop, tamper event, or missing heartbeat on critical host.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-039. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Sensor health alert, policy disable, service stop, tamper event, or missing heartbeat on critical host. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts,	Remediation tasks completed/assigned

Step	SOAR / Analyst Action	Expected Output
	patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-039_EDR_TAMPERING_DISABLED
ON: alert where rule_family == "EDR_TAMPERING_DISABLED"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for EDR Tampering / Disabled. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'EDR Tampering / Disabled' involving user039@orionbank.example / WKS-763 and source 203.0.113.24.
09:03	Normalize	SOAR creates SOAR-039, stores raw event,

Time	Stage	Simulation
		extracts IP 203.0.113.24, domain case039-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.24 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.180 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-039.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-040 - Antivirus Disabled

Domain: Endpoint & Malware

Objective	Detect and reverse unauthorized disabling of AV or antimalware protections.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Security product reports disablement, exclusion changes, or protection state change outside policy.
ATT&CK v19.2 mapping	T1562.001 Impair Defenses: Disable or Modify Tools
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Security product reports disablement, exclusion changes, or protection state change outside policy.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.

- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-040. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Security product reports disablement, exclusion changes, or protection state change outside policy. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.

- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-040_ANTIVIRUS_DISABLED
ON: alert where rule_family == "ANTIVIRUS_DISABLED"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Antivirus Disabled. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Antivirus Disabled' involving user040@orionbank.example / WKS-780 and source 203.0.113.31.
09:03	Normalize	SOAR creates SOAR-040, stores raw event, extracts IP 203.0.113.31, domain case040-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.31 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.191 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-040.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained

Time	Stage	Simulation
		with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-041 - Log Clearing / Event Log Tampering

Domain: Endpoint & Malware

Objective	Preserve remaining evidence and investigate attempts to remove or alter local security logs.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Windows/Linux/macOS log clearing, audit policy change, or sudden event-log gap is observed.
ATT&CK v19.2 mapping	T1070.001 Clear Windows Event Logs; T1070.002 Clear Linux or Mac System Logs
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Windows/Linux/macOS log clearing, audit policy change, or sudden event-log gap is observed.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-041. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated	Risk score + severity

Step	SOAR / Analyst Action	Expected Output
	signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	
5. Validate the trigger	Test the core hypothesis for this use case: Windows/Linux/macOS log clearing, audit policy change, or sudden event-log gap is observed. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-041_LOG_CLEARING_EVENT_LOG_TAMPERING
ON: alert where rule_family == "LOG_CLEARING_EVENT_LOG_TAMPERING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Log Clearing / Event Log Tampering. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Log Clearing / Event Log Tampering' involving user041@orionbank.example / WKS-797 and source 203.0.113.38.
09:03	Normalize	SOAR creates SOAR-041, stores raw event, extracts IP 203.0.113.38, domain case041-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.38 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.202 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-041.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-042 - Scheduled Task Persistence

Domain: Endpoint & Malware

Objective	Validate newly created scheduled tasks and remove malicious persistence.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New/modified scheduled task executes unusual binary/script or runs under suspicious account/context.
ATT&CK v19.2 mapping	T1053 Scheduled Task/Job
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New/modified scheduled task executes unusual binary/script or runs under suspicious account/context.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-042. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New/modified scheduled task executes unusual binary/script or runs under suspicious account/context. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows	Approved/denied/conditional action plan

Step	SOAR / Analyst Action	Expected Output
	confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-042_SCHEDULED_TASK_PERSISTENCE
ON: alert where rule_family == "SCHEDULED_TASK_PERSISTENCE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```


7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Scheduled Task Persistence. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Scheduled Task Persistence' involving user042@orionbank.example / WKS-814 and source 203.0.113.45.
09:03	Normalize	SOAR creates SOAR-042, stores raw event, extracts IP 203.0.113.45, domain case042-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.45 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.213 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-042.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-043 - Service Creation Persistence

Domain: *Endpoint & Malware*

Objective	Detect malicious service creation or modification used for persistence or remote execution.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New service, driver, or service binary path appears outside approved software deployment.
ATT&CK v19.2 mapping	T1543 Create or Modify System Process
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New service, driver, or service binary path appears outside approved software deployment.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-043. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New service, driver, or service binary path appears outside approved software deployment. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-043_SERVICE_CREATION_PERSISTENCE
ON: alert where rule_family == "SERVICE_CREATION_PERSISTENCE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Service Creation Persistence. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Service Creation Persistence' involving user043@orionbank.example / WKS-831 and source 203.0.113.52.
09:03	Normalize	SOAR creates SOAR-043, stores raw event, extracts IP 203.0.113.52, domain case043-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.52 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.224 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity

Time	Stage	Simulation
		exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-043.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-044 - Registry Run Key Persistence

Domain: Endpoint & Malware

Objective	Detect and remove unauthorized autorun registry persistence.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Run/RunOnce or related startup registry locations are modified by suspicious process/account.
ATT&CK v19.2 mapping	T1060/T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Run/RunOnce or related startup registry locations are modified by suspicious process/account.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-044. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Run/RunOnce or related startup registry locations are modified by suspicious process/account. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24

extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-044_REGISTRY_RUN_KEY_PERSISTENCE
ON: alert where rule_family == "REGISTRY_RUN_KEY_PERSISTENCE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Registry Run Key Persistence. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Registry Run Key Persistence' involving user044@orionbank.example / WKS-848 and source 203.0.113.59.
09:03	Normalize	SOAR creates SOAR-044, stores raw event, extracts IP 203.0.113.59, domain case044-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.59 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.235 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-044.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.

- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-045 - Remote Monitoring / Management Tool Abuse

Domain: Endpoint & Malware

Objective	Detect attacker use of legitimate remote-management tools for persistence, execution, or lateral movement.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Unapproved RMM tool installation, new agent, unexpected remote session, or mass deployment is detected.
ATT&CK v19.2 mapping	T1219 Remote Access Software
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Unapproved RMM tool installation, new agent, unexpected remote session, or mass deployment is detected.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-045. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Unapproved RMM tool installation, new agent, unexpected remote session, or mass deployment is detected. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the	Evidence package references

Step	SOAR / Analyst Action	Expected Output
7. Run scoped hunt	case with timestamps and source system. Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-045_REMOTE_MONITORING_MANAGEMENT_TOOL_ABUSE
ON: alert where rule_family == "REMOTE_MONITORING_MANAGEMENT_TOOL_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:

```

```

        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Remote Monitoring / Management Tool Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Remote Monitoring / Management Tool Abuse' involving user045@orionbank.example / WKS-865 and source 203.0.113.66.
09:03	Normalize	SOAR creates SOAR-045, stores raw event, extracts IP 203.0.113.66, domain case045-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.66 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.246 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-045.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-046 - PsExec Lateral Movement

Domain: Endpoint & Malware

Objective	Contain remote execution using PsExec-like service creation and administrative shares.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Service creation/admin share access indicates PsExec or equivalent remote execution.
ATT&CK v19.2 mapping	T1569.002 System Services: Service Execution; T1021.002 SMB/Windows Admin Shares
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Service creation/admin share access indicates PsExec or equivalent remote execution.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-046. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Service creation/admin share access indicates PsExec or equivalent remote execution. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned

Step	SOAR / Analyst Action	Expected Output
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-046_PSEXEC_LATERAL_MOVEMENT
ON: alert where rule_family == "PSEXEC_LATERAL_MOVEMENT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for PsExec Lateral Movement. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'PsExec Lateral Movement' involving user046@orionbank.example / WKS-882 and source 203.0.113.73.
09:03	Normalize	SOAR creates SOAR-046, stores raw event, extracts IP 203.0.113.73, domain case046-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.73 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is

Time	Stage	Simulation
09:05	Correlation	found. SOAR finds two related events from 198.51.100.7 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-046.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-047 - WMI Lateral Movement

Domain: Endpoint & Malware

Objective	Detect remote execution or persistence using Windows Management Instrumentation.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Remote WMI process creation or event subscription occurs from unusual source or account.
ATT&CK v19.2 mapping	T1047 Windows Management Instrumentation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Remote WMI process creation or event subscription occurs from unusual source or account.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-047. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Remote WMI process creation or event subscription occurs from unusual source or account. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.

- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-047_WMI_LATERAL_MOVEMENT
ON: alert where rule_family == "WMI_LATERAL_MOVEMENT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for WMI Lateral Movement. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'WMI Lateral Movement' involving user047@orionbank.example / WKS-899 and source 203.0.113.80.
09:03	Normalize	SOAR creates SOAR-047, stores raw event, extracts IP 203.0.113.80, domain case047-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.80 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.18 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-047.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-048 - RDP Lateral Movement

Domain: Endpoint & Malware

Objective	Detect compromised-account movement over RDP and contain source/destination systems.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New RDP sessions between unusual hosts/users, especially after credential theft or VPN compromise.
ATT&CK v19.2 mapping	T1021.001 Remote Services: Remote Desktop Protocol
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New RDP sessions between unusual hosts/users, especially after credential theft or VPN compromise.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-048. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	RDP sessions between unusual hosts/users, especially after credential theft or VPN compromise. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-048_RDP_LATERAL_MOVEMENT
ON: alert where rule_family == "RDP_LATERAL_MOVEMENT"
DO:
    normalize(alert)

```

```

case = dedupe_or_create(correlation_key, window=60m)
enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for RDP Lateral Movement. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'RDP Lateral Movement' involving user048@orionbank.example / WKS-916 and source 203.0.113.87.
09:03	Normalize	SOAR creates SOAR-048, stores raw event, extracts IP 203.0.113.87, domain case048-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.87 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.29 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-048.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-049 - SMB / Admin Share Lateral Movement

Domain: Endpoint & Malware

Objective	Detect suspicious use of ADMIN\$, C\$, IPC\$, and SMB to move tools or execute remotely.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision

Primary trigger	Unusual admin-share connection, remote file copy, or SMB session from user workstation to multiple hosts.
ATT&CK v19.2 mapping	T1021.002 SMB/Windows Admin Shares
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Unusual admin-share connection, remote file copy, or SMB session from user workstation to multiple hosts.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-049. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Unusual admin-share connection, remote file copy, or SMB session from user workstation to multiple hosts. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-049_SMB_ADMIN_SHARE_LATERAL_MOVEMENT
ON: alert where rule_family == "SMB_ADMIN_SHARE_LATERAL_MOVEMENT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for SMB / Admin Share Lateral Movement. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'SMB / Admin Share Lateral Movement' involving user049@orionbank.example / WKS-933 and source 203.0.113.94.
09:03	Normalize	SOAR creates SOAR-049, stores raw event, extracts IP 203.0.113.94, domain case049-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.94 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.40 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-049.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-050 - Suspicious Script / Office Macro Execution

Domain: Endpoint & Malware

Objective	Detect macro/script-driven initial execution and contain resulting endpoint activity.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Office/browser/document process launches script engine, shell, or child process with suspicious behavior.
ATT&CK v19.2 mapping	T1204.002 User Execution: Malicious File; T1059 Command and Scripting Interpreter
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- EDR/AV process tree, file, registry, service, network, sensor-health telemetry
- SIEM authentication and host activity around the alert window
- Threat-intelligence/hash/domain/IP reputation
- Asset criticality, owner, operating system, server role and business service
- Forensic collection capability and endpoint isolation action

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Office/browser/document process launches script engine, shell, or child process with suspicious behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-050. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Office/browser/document process launches script engine, shell, or child process with suspicious behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related network indicators. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If execution is confirmed or malicious behavior is active, isolate the host; if only a blocked file is observed with no execution, hunt related artifacts before deciding whether isolation is necessary.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-050_SUSPICIOUS_SCRIPT_OFFICE_MACRO_EXECUTION
ON: alert where rule_family == "SUSPICIOUS_SCRIPT_OFFICE_MACRO_EXECUTION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Suspicious Script / Office Macro Execution. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Suspicious Script / Office Macro Execution' involving user050@orionbank.example / WKS-950 and source 203.0.113.101.
09:03	Normalize	SOAR creates SOAR-050, stores raw event, extracts IP 203.0.113.101, domain case050-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.101 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.51 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Isolate affected endpoint/workload, kill or block malicious process/hash, preserve forensic artifacts, disable compromised credentials, and block related

Time	Stage	Simulation
09:14	Enterprise hunt	network indicators. Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-050.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-051 - Command-and-Control Beaconing

Domain: Network & Perimeter

Objective	Identify periodic or stealthy C2 traffic and isolate affected endpoints or workloads.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	NDR/proxy/firewall detects regular beaconing, rare destinations, TLS anomalies, or known C2 infrastructure.
ATT&CK v19.2 mapping	T1071 Application Layer Protocol; T1105 Ingress Tool Transfer
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- NDR/proxy/firewall detects regular beaconing, rare destinations, TLS anomalies, or known C2 infrastructure.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-051. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident

Step	SOAR / Analyst Action	Expected Output
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: NDR/proxy/firewall detects regular beaconing, rare destinations, TLS anomalies, or known C2 infrastructure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions

block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-051_COMMAND_AND_CONTROL_BEACONING
ON: alert where rule_family == "COMMAND_AND_CONTROL_BEACONING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Command-and-Control Beaconing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Command-and-Control Beaconing' involving user051@orionbank.example / WKS-967 and source 203.0.113.108.
09:03	Normalize	SOAR creates SOAR-051, stores raw event, extracts IP 203.0.113.108, domain case051-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.108 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.62 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-051.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.

- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-052 - DNS Tunneling

Domain: Network & Perimeter

Objective	Detect encoded/high-entropy DNS used for command-and-control or exfiltration.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	DNS telemetry shows long labels, high entropy, excessive TXT queries, or anomalous query volume to rare domain.
ATT&CK v19.2 mapping	T1071.004 Application Layer Protocol: DNS; T1048 Exfiltration Over Alternative Protocol
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- DNS telemetry shows long labels, high entropy, excessive TXT queries, or anomalous query volume to rare domain.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-052. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: DNS telemetry shows long labels, high entropy, excessive TXT queries, or anomalous query volume to rare domain. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process,	Blast-radius result set

Step	SOAR / Analyst Action	Expected Output
	file, sender, token/app, source IP or behavior across the enterprise.	
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-052_DNS_TUNNELING
ON: alert where rule_family == "DNS_TUNNELING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()

```

```

    eradicate_root_cause()
    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for DNS Tunneling. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'DNS Tunneling' involving user052@orionbank.example / WKS-984 and source 203.0.113.115.
09:03	Normalize	SOAR creates SOAR-052, stores raw event, extracts IP 203.0.113.115, domain case052-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.115 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.73 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-052.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-053 - DGA / Anomalous DNS

Domain: Network & Perimeter

Objective	Detect algorithmically generated or newly observed domains associated with malware and C2.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	High NXDOMAIN rate, random-looking domains, domain-age risk, or rare-domain bursts from endpoint.
ATT&CK v19.2 mapping	T1568.002 Dynamic Resolution: Domain Generation Algorithms
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- High NXDOMAIN rate, random-looking domains, domain-age risk, or rare-domain bursts from endpoint.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-053. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: High NXDOMAIN rate, random-looking domains, domain-age risk, or rare-domain bursts from endpoint. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned

Step	SOAR / Analyst Action	Expected Output
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-053_DGA_ANOMALOUS_DNS
ON: alert where rule_family == "DGA_ANOMALOUS_DNS"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for DGA / Anomalous DNS. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'DGA / Anomalous DNS' involving user053@orionbank.example / WKS-101 and source 203.0.113.122.
09:03	Normalize	SOAR creates SOAR-053, stores raw event, extracts IP 203.0.113.122, domain case053-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.122 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is

Time	Stage	Simulation
09:05	Correlation	found. SOAR finds two related events from 198.51.100.84 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-053.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-054 - TOR / Anonymous Proxy Traffic

Domain: Network & Perimeter

Objective	Investigate unexpected anonymizer usage that may hide attacker access or exfiltration.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Firewall/proxy detects TOR exit/node traffic or unauthorized anonymization service from corporate asset.
ATT&CK v19.2 mapping	T1090 Proxy
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Firewall/proxy detects TOR exit/node traffic or unauthorized anonymization service from corporate asset.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-054. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Firewall/proxy detects TOR exit/node traffic or unauthorized anonymization service from corporate asset. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.

- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-054_TOR_ANONYMOUS_PROXY_TRAFFIC
ON: alert where rule_family == "TOR_ANONYMOUS_PROXY_TRAFFIC"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for TOR / Anonymous Proxy Traffic. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'TOR / Anonymous Proxy Traffic' involving user054@orionbank.example / WKS-118 and source 203.0.113.129.
09:03	Normalize	SOAR creates SOAR-054, stores raw event, extracts IP 203.0.113.129, domain case054-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.129 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.95 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-054.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-055 - Inbound Threat-Intel IOC Hit

Domain: Network & Perimeter

Objective	Evaluate inbound connection from known malicious infrastructure and determine whether exploitation succeeded.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Firewall/WAF/IPS event matches high-confidence malicious IP/domain indicator targeting organizational asset.
ATT&CK v19.2 mapping	T1595 Active Scanning; T1190 Exploit Public-Facing Application
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Firewall/WAF/IPS event matches high-confidence malicious IP/domain indicator targeting organizational asset.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-055. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case:	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	Firewall/WAF/IPS event matches high-confidence malicious IP/domain indicator targeting organizational asset. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-055_INBOUND_THREAT_INTEL_IOC_HIT
ON: alert where rule_family == "INBOUND_THREAT_INTEL_IOC_HIT"
```

```

DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Inbound Threat-Intel IOC Hit. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Inbound Threat-Intel IOC Hit' involving user055@orionbank.example / WKS-135 and source 203.0.113.136.
09:03	Normalize	SOAR creates SOAR-055, stores raw event, extracts IP 203.0.113.136, domain case055-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.136 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.106 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-055.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-056 - Outbound Threat-Intel IOC Hit

Domain: Network & Perimeter

Objective	Treat outbound communication to malicious infrastructure as potential compromise and identify the originating asset.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Firewall/proxy/DNS/EDR sees internal host reaching known malicious IP/domain/URL.
ATT&CK v19.2 mapping	T1071 Application Layer Protocol; T1105 Ingress Tool Transfer
Automation posture	Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Firewall/proxy/DNS/EDR sees internal host reaching known malicious IP/domain/URL.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-056. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Firewall/proxy/DNS/EDR sees internal host reaching known malicious IP/domain/URL. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-056_OUTBOUND_THREAT_INTEL_IOC_HIT
ON: alert where rule_family == "OUTBOUND_THREAT_INTEL_IOC_HIT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Outbound Threat-Intel IOC Hit. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Outbound Threat-Intel IOC Hit' involving user056@orionbank.example / WKS-152 and source 203.0.113.143.
09:03	Normalize	SOAR creates SOAR-056, stores raw event, extracts IP 203.0.113.143, domain case056-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.143 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.117 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-056.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-057 - Internal Network Scanning / Recon

Domain: Network & Perimeter

Objective	Detect compromised hosts performing host, port, service, or share discovery inside the network.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	One internal source touches many hosts/ports/services within a short period or runs known discovery pattern.
ATT&CK v19.2 mapping	T1046 Network Service Discovery
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- One internal source touches many hosts/ports/services within a short period or runs known discovery pattern.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-057. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: One internal source touches many hosts/ports/services within a short period or runs known discovery pattern. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence,	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-057_INTERNAL_NETWORK_SCANNING_RECON
ON: alert where rule_family == "INTERNAL_NETWORK_SCANNING_RECON"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Internal Network Scanning / Recon. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Internal Network Scanning / Recon' involving user057@orionbank.example / WKS-169 and source 203.0.113.150.
09:03	Normalize	SOAR creates SOAR-057, stores raw event, extracts IP 203.0.113.150, domain case057-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.150 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.128 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.

Time	Stage	Simulation
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-057.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-058 - External Scanning Against Public Asset

Domain: Network & Perimeter

Objective	Prioritize internet reconnaissance against critical assets and distinguish blocked scanning from successful intrusion.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Public-facing asset receives scanning/probing from suspicious infrastructure across ports/paths.
ATT&CK v19.2 mapping	T1595 Active Scanning
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Public-facing asset receives scanning/probing from suspicious infrastructure across ports/paths.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-058. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
	payload.	
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Public-facing asset receives scanning/probing from suspicious infrastructure across ports/paths. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-058_EXTERNAL_SCANNING_AGAINST_PUBLIC_ASSET
ON: alert where rule_family == "EXTERNAL_SCANNING_AGAINST_PUBLIC_ASSET"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for External Scanning Against Public Asset. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'External Scanning Against Public Asset' involving user058@orionbank.example / WKS-186 and source 203.0.113.157.
09:03	Normalize	SOAR creates SOAR-058, stores raw event, extracts IP 203.0.113.157, domain case058-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.157 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.139 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-058.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.

- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-059 - Exploitation of Public-Facing Application

Domain: Network & Perimeter

Objective	Contain likely successful exploitation of internet-facing applications and validate downstream compromise.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	WAF/IPS/EDR shows exploit signature plus suspicious child process, web shell, or unexpected outbound traffic.
ATT&CK v19.2 mapping	T1190 Exploit Public-Facing Application
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- WAF/IPS/EDR shows exploit signature plus suspicious child process, web shell, or unexpected outbound traffic.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-059. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: WAF/IPS/EDR shows exploit signature plus suspicious child process, web shell, or unexpected outbound traffic. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
6. Preserve evidence	for the classification. Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-059_EXPLOITATION_OF_PUBLIC_FACING_APPLICATION
ON: alert where rule_family == "EXPLOITATION_OF_PUBLIC_FACING_APPLICATION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:

```

```

IF score >= 85 AND not critical_exception:
    execute_guarded_containment()
ELSE:
    request_analyst_decision()
    eradicate_root_cause()
    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Exploitation of Public-Facing Application. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Exploitation of Public-Facing Application' involving user059@orionbank.example / WKS-203 and source 203.0.113.164.
09:03	Normalize	SOAR creates SOAR-059, stores raw event, extracts IP 203.0.113.164, domain case059-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.164 as suspicious; CMDDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.150 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-059.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-060 - VPN Brute Force / Account Takeover

Domain: Network & Perimeter

Objective	Block abusive VPN authentication and contain accounts when successful attacker access is suspected.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	VPN shows repeated failures, distributed spray, impossible geo, or success following brute-force activity.
ATT&CK v19.2 mapping	T1110 Brute Force; T1133 External Remote Services
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- VPN shows repeated failures, distributed spray, impossible geo, or success following brute-force activity.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-060. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: VPN shows repeated failures, distributed spray, impossible geo, or success following brute-force activity. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized	Remediation tasks completed/assigned

Step	SOAR / Analyst Action	Expected Output
	permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-060_VPN_BRUTE_FORCE_ACCOUNT_TAKEOVER
ON: alert where rule_family == "VPN_BRUTE_FORCE_ACCOUNT_TAKEOVER"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for VPN Brute Force / Account Takeover. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'VPN Brute Force / Account Takeover' involving user060@orionbank.example / WKS-220 and source 203.0.113.171.
09:03	Normalize	SOAR creates SOAR-060, stores raw event, extracts IP 203.0.113.171, domain case060-verify.example and relevant entity identifiers.

Time	Stage	Simulation
09:04	Enrichment	Threat intelligence scores 203.0.113.171 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.161 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-060.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-061 - Firewall Critical Configuration Change

Domain: Network & Perimeter

Objective	Validate and reverse unauthorized perimeter rule, NAT, logging, or admin changes.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Firewall audit log reports critical configuration change outside approved change ticket/window.
ATT&CK v19.2 mapping	T1562.004 Impair Defenses: Disable or Modify System Firewall; T1098 Account Manipulation
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Firewall audit log reports critical configuration change outside approved change ticket/window.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.

- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-061. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Firewall audit log reports critical configuration change outside approved change ticket/window. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.

- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-061_FIREWALL_CRITICAL_CONFIGURATION_CHANGE
ON: alert where rule_family == "FIREWALL_CRITICAL_CONFIGURATION_CHANGE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Firewall Critical Configuration Change. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Firewall Critical Configuration Change' involving user061@orionbank.example / WKS-237 and source 203.0.113.178.
09:03	Normalize	SOAR creates SOAR-061, stores raw event, extracts IP 203.0.113.178, domain case061-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.178 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.172 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-061.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained

Time	Stage	Simulation
		with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-062 - Network Device Admin Compromise

Domain: Network & Perimeter

Objective	Contain compromised router/switch/firewall administrator accounts and preserve configuration evidence.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	New admin login, config export, new user, ACL change, or suspicious management access occurs.
ATT&CK v19.2 mapping	T1078 Valid Accounts; T1601 Modify System Image
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New admin login, config export, new user, ACL change, or suspicious management access occurs.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-062. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated	Risk score + severity

Step	SOAR / Analyst Action	Expected Output
	signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	
5. Validate the trigger	Test the core hypothesis for this use case: New admin login, config export, new user, ACL change, or suspicious management access occurs. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-062_NETWORK_DEVICE_ADMIN_COMPROMISE
ON: alert where rule_family == "NETWORK_DEVICE_ADMIN_COMPROMISE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Network Device Admin Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Network Device Admin Compromise' involving user062@orionbank.example / WKS-254 and source 203.0.113.185.
09:03	Normalize	SOAR creates SOAR-062, stores raw event, extracts IP 203.0.113.185, domain case062-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.185 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.183 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-062.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-063 - IPS / IDS Critical Exploit Alert

Domain: Network & Perimeter

Objective	Triage high-confidence exploit detections and correlate with endpoint/app evidence before containment.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	IPS/IDS generates critical exploit alert against high-value target or known exploited vulnerability.
ATT&CK v19.2 mapping	T1190 Exploit Public-Facing Application
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- IPS/IDS generates critical exploit alert against high-value target or known exploited vulnerability.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-063. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: IPS/IDS generates critical exploit alert against high-value target or known exploited vulnerability. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows	Approved/denied/conditional action plan

Step	SOAR / Analyst Action	Expected Output
	confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-063_IPS_IDS_CRITICAL_EXPLOIT_ALERT
ON: alert where rule_family == "IPS_IDS_CRITICAL_EXPLOIT_ALERT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")

```

never_mark_closed_on_action_failure

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for IPS / IDS Critical Exploit Alert. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'IPS / IDS Critical Exploit Alert' involving user063@orionbank.example / WKS-271 and source 203.0.113.192.
09:03	Normalize	SOAR creates SOAR-063, stores raw event, extracts IP 203.0.113.192, domain case063-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.192 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.194 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-063.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-064 - Unexpected East-West Traffic

Domain: Network & Perimeter

Objective	Detect lateral movement based on abnormal internal communications between security zones or asset classes.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Network telemetry shows new protocol/path between hosts that do not normally communicate.
ATT&CK v19.2 mapping	T1021 Remote Services; T1046 Network Service Discovery
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host

- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Network telemetry shows new protocol/path between hosts that do not normally communicate.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-064. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Network telemetry shows new protocol/path between hosts that do not normally communicate. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence,	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-064_UNEXPECTED_EAST_WEST_TRAFFIC
ON: alert where rule_family == "UNEXPECTED_EAST_WEST_TRAFFIC"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Unexpected East-West Traffic. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Unexpected East-West Traffic' involving user064@orionbank.example / WKS-288 and source 203.0.113.199.
09:03	Normalize	SOAR creates SOAR-064, stores raw event, extracts IP 203.0.113.199, domain case064-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.199 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.205 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.

Time	Stage	Simulation
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-064.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-065 - Unauthorized Remote Access Port Exposure

Domain: Network & Perimeter

Objective	Close accidental or malicious exposure of RDP, SSH, database, admin, or management ports to untrusted networks.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	External scan/config monitoring finds sensitive service reachable from internet or untrusted zone.
ATT&CK v19.2 mapping	T1133 External Remote Services
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Firewall, proxy/SWG, DNS, VPN, NDR, IDS/IPS and NetFlow telemetry
- Asset inventory, network zone, public exposure and application owner
- Threat-intelligence enrichment for IP/domain/URL
- EDR/identity context for the internal source or targeted host
- Firewall/IPS/SWG blocking APIs and change-management integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- External scan/config monitoring finds sensitive service reachable from internet or untrusted zone.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-065. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
	raw-event references. Preserve the original alert payload.	
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: External scan/config monitoring finds sensitive service reachable from internet or untrusted zone. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- A firewall/IPS block alone is not proof of host compromise; only escalate to containment when follow-on traffic, successful sessions, exploit evidence, or endpoint indicators exist.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-065_UNAUTHORIZED_REMOTE_ACCESS_PORT_EXPOSURE
ON: alert where rule_family == "UNAUTHORIZED_REMOTE_ACCESS_PORT_EXPOSURE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Unauthorized Remote Access Port Exposure. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Unauthorized Remote Access Port Exposure' involving user065@orionbank.example / WKS-305 and source 203.0.113.206.
09:03	Normalize	SOAR creates SOAR-065, stores raw event, extracts IP 203.0.113.206, domain case065-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.206 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.216 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block malicious source/destination where safe, rate-limit or geo-restrict when appropriate, isolate compromised internal source, and preserve firewall/packet/log evidence before configuration rollback.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-065.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-066 - SQL Injection

Domain: Web & API

Objective	Block SQL injection attempts, determine whether database access succeeded, and remediate vulnerable application paths.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	WAF/app logs detect SQLi payload or database errors correlated with suspicious request.
ATT&CK v19.2 mapping	T1190 Exploit Public-Facing Application
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- WAF/app logs detect SQLi payload or database errors correlated with suspicious request.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-066. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity

Step	SOAR / Analyst Action	Expected Output
5. Validate the trigger	Test the core hypothesis for this use case: WAF/app logs detect SQLi payload or database errors correlated with suspicious request. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-066_SQL_INJECTION
ON: alert where rule_family == "SQL_INJECTION"
DO:

```

```

normalize(alert)
case = dedupe_or_create(correlation_key, window=60m)
enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for SQL Injection. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'SQL Injection' involving user066@orionbank.example / WKS-322 and source 203.0.113.213.
09:03	Normalize	SOAR creates SOAR-066, stores raw event, extracts IP 203.0.113.213, domain case066-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.213 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.227 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-066.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-067 - Command Injection

Domain: Web & API

Objective	Contain web requests that trigger OS command execution and validate host compromise.
Default severity	High

Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	WAF/app/EDR shows metacharacter injection, shell child process, or suspicious command from web-service account.
ATT&CK v19.2 mapping	T1190 Exploit Public-Facing Application; T1059 Command and Scripting Interpreter
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- WAF/app/EDR shows metacharacter injection, shell child process, or suspicious command from web-service account.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-067. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: WAF/app/EDR shows metacharacter injection, shell child process, or suspicious command from web-service account. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	remediation. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-067_COMMAND_INJECTION
ON: alert where rule_family == "COMMAND_INJECTION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Command Injection. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Command Injection' involving user067@orionbank.example / WKS-339 and source 203.0.113.220.
09:03	Normalize	SOAR creates SOAR-067, stores raw event, extracts IP 203.0.113.220, domain case067-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.220 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.238 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-067.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-068 - Path Traversal / LFI / RFI

Domain: Web & API

Objective	Detect attempts to read local files or include remote/local resources through path manipulation.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	WAF/app logs show traversal sequences, sensitive file access, or unexpected include behavior.
ATT&CK v19.2 mapping	T1190 Exploit Public-Facing Application
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- WAF/app logs show traversal sequences, sensitive file access, or unexpected include behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-068. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: WAF/app logs show traversal sequences, sensitive file access, or unexpected include behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-068_PATH_TRAVERSAL_LFI_RFI
ON: alert where rule_family == "PATH_TRAVERSAL_LFI_RFI"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Path Traversal / LFI / RFI. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Path Traversal / LFI / RFI' involving user068@orionbank.example / WKS-356 and source 203.0.113.227.
09:03	Normalize	SOAR creates SOAR-068, stores raw event, extracts IP 203.0.113.227, domain case068-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.227 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.249 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration

Time	Stage	Simulation
09:14	Enterprise hunt	remediation. Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-068.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-069 - Server-Side Request Forgery (SSRF)

Domain: Web & API

Objective	Detect SSRF used to reach metadata services, internal hosts, or restricted endpoints.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Application makes server-side requests to internal/metadata addresses based on attacker-controlled input.
ATT&CK v19.2 mapping	T1190 Exploit Public-Facing Application; T1552.005 Unsecured Credentials: Cloud Instance Metadata API
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Application makes server-side requests to internal/metadata addresses based on attacker-controlled input.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-069. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident

Step	SOAR / Analyst Action	Expected Output
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Application makes server-side requests to internal/metadata addresses based on attacker-controlled input. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions

block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-069_SERVER_SIDE_REQUEST_FORGERY_SSRF
ON: alert where rule_family == "SERVER_SIDE_REQUEST_FORGERY_SSRF"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Server-Side Request Forgery (SSRF). The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Server-Side Request Forgery (SSRF)' involving user069@orionbank.example / WKS-373 and source 203.0.113.234.
09:03	Normalize	SOAR creates SOAR-069, stores raw event, extracts IP 203.0.113.234, domain case069-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.234 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.10 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-069.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.

- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-070 - Web Shell Detection

Domain: Web & API

Objective	Isolate compromised web servers, preserve shell artifacts, and block related indicators.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	File-integrity/EDR detects suspicious web-accessible script, command execution, or unauthorized webroot change.
ATT&CK v19.2 mapping	T1505.003 Server Software Component: Web Shell
Automation posture	Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- File-integrity/EDR detects suspicious web-accessible script, command execution, or unauthorized webroot change.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-070. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: File-integrity/EDR detects suspicious web-accessible script, command execution, or unauthorized webroot change. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process,	Blast-radius result set

Step	SOAR / Analyst Action	Expected Output
	file, sender, token/app, source IP or behavior across the enterprise.	
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Conditional auto-containment: allow automatic isolation/blocking only when confidence is high and the target is not on the critical-asset exception list. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-070_WEB_SHELL_DETECTION
ON: alert where rule_family == "WEB_SHELL_DETECTION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()

```

```

    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Web Shell Detection. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Web Shell Detection' involving user070@orionbank.example / WKS-390 and source 203.0.113.241.
09:03	Normalize	SOAR creates SOAR-070, stores raw event, extracts IP 203.0.113.241, domain case070-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.241 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.21 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-070.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-071 - Web Credential Stuffing

Domain: Web & API

Objective	Protect customer/user portals from automated takeover using reused credentials.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Application authentication sees high-volume distributed login attempts with many username/password pairs.
ATT&CK v19.2 mapping	T1110.004 Credential Stuffing
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Application authentication sees high-volume distributed login attempts with many username/password pairs.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-071. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Application authentication sees high-volume distributed login attempts with many username/password pairs. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
	after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-071_WEB_CREDENTIAL_STUFFING
ON: alert where rule_family == "WEB_CREDENTIAL_STUFFING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Web Credential Stuffing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Web Credential Stuffing' involving user071@orionbank.example / WKS-407 and source 203.0.113.248.
09:03	Normalize	SOAR creates SOAR-071, stores raw event, extracts IP 203.0.113.248, domain case071-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.248 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.

Time	Stage	Simulation
09:05	Correlation	SOAR finds two related events from 198.51.100.32 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-071.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-072 - API Abuse / Token Misuse

Domain: Web & API

Objective	Detect abusive API use caused by stolen tokens, automation, or scope misuse.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	API gateway sees impossible rate, unusual methods, new source, or privilege use inconsistent with token owner.
ATT&CK v19.2 mapping	T1078 Valid Accounts; T1528 Steal Application Access Token
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- API gateway sees impossible rate, unusual methods, new source, or privilege use inconsistent with token owner.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-072. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: API gateway sees impossible rate, unusual methods, new source, or privilege use inconsistent with token owner. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.

- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minute	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-072_API_ABUSE_TOKEN_MISUSE
ON: alert where rule_family == "API_ABUSE_TOKEN_MISUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for API Abuse / Token Misuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'API Abuse / Token Misuse' involving user072@orionbank.example / WKS-424 and source 203.0.113.5.
09:03	Normalize	SOAR creates SOAR-072, stores raw event, extracts IP 203.0.113.5, domain case072-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.5 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.43 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-072.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-073 - API Key Abuse

Domain: Web & API

Objective	Revoke abused API keys and determine exposure path and impact.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	API key is used from unapproved IP/region, exceeds normal rate, or accesses new sensitive endpoints.
ATT&CK v19.2 mapping	T1552 Unsecured Credentials; T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- API key is used from unapproved IP/region, exceeds normal rate, or accesses new sensitive endpoints.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-073. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: API key	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	is used from unapproved IP/region, exceeds normal rate, or accesses new sensitive endpoints. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-073_API_KEY_ABUSE
ON: alert where rule_family == "API_KEY_ABUSE"
DO:

```



```

normalize(alert)
case = dedupe_or_create(correlation_key, window=60m)
enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for API Key Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'API Key Abuse' involving user073@orionbank.example / WKS-441 and source 203.0.113.12.
09:03	Normalize	SOAR creates SOAR-073, stores raw event, extracts IP 203.0.113.12, domain case073-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.12 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.54 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-073.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-074 - Malicious Bot / Automated Abuse

Domain: Web & API

Objective	Mitigate abusive automation that performs scraping, enumeration, fraud, or resource exhaustion.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Bot-management/WAF detects automated session pattern, headless behavior, or abusive request volume.
ATT&CK v19.2 mapping	T1110 Brute Force; T1595 Active Scanning
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Bot-management/WAF detects automated session pattern, headless behavior, or abusive request volume.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-074. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Bot-management/WAF detects automated session pattern, headless behavior, or abusive request volume. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-074_MALICIOUS_BOT_AUTOMATED_ABUSE
ON: alert where rule_family == "MALICIOUS_BOT_AUTOMATED_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Malicious Bot / Automated Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Malicious Bot / Automated Abuse' involving user074@orionbank.example / WKS-458 and source 203.0.113.19.
09:03	Normalize	SOAR creates SOAR-074, stores raw event, extracts IP 203.0.113.19, domain case074-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.19 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.65 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-074.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-075 - Web Defacement / Integrity Change

Domain: Web & API

Objective	Restore trusted content and identify the compromise path when public web content is altered.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	File-integrity monitoring, synthetic checks, or user report confirms unauthorized public content change.
ATT&CK v19.2 mapping	T1491.002 Defacement: External Defacement
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- WAF, reverse proxy, API gateway and application access/error logs
- EDR/runtime telemetry on application servers
- Database audit and cloud metadata access logs where applicable
- Asset/application owner, code repository and change/deployment context
- WAF/API rate-limit/block controls and ticketing integration

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- File-integrity monitoring, synthetic checks, or user report confirms unauthorized public content change.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-075. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: File-integrity monitoring, synthetic checks, or user report confirms unauthorized public content change. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation. Specific actions: correlate WAF request with application/EDR evidence; capture request parameters and response status safely; open emergency remediation ticket for vulnerable route or API.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the WAF blocked the request and no application/host impact exists, record as prevented; if suspicious child process, file change, DB access, or outbound traffic exists, treat as compromise.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-075_WEB_DEFACEMENT_INTEGRITY_CHANGE
ON: alert where rule_family == "WEB_DEFACEMENT_INTEGRITY_CHANGE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Web Defacement / Integrity Change. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Web Defacement / Integrity Change' involving user075@orionbank.example / WKS-475 and source 203.0.113.26.
09:03	Normalize	SOAR creates SOAR-075, stores raw event, extracts IP 203.0.113.26, domain case075-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.26 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.76 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity

Time	Stage	Simulation
		exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Block or challenge malicious requests, disable exposed tokens/keys, isolate compromised application host if execution occurred, and coordinate emergency code/configuration remediation.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-075.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-076 - Mass Cloud File Download

Domain: Cloud & SaaS

Objective	Detect bulk download consistent with account takeover, insider activity, or staging for exfiltration.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Cloud audit logs show unusual volume/count of file downloads from one user/app/session.
ATT&CK v19.2 mapping	T1213 Data from Information Repositories; T1020 Automated Exfiltration
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Cloud audit logs show unusual volume/count of file downloads from one user/app/session.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-076. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Cloud audit logs show unusual volume/count of file downloads from one user/app/session. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud audit logs before retention or tenant changes; compare activity to approved IaC/change records.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24

extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-076_MASS_CLOUD_FILE_DOWNLOAD
ON: alert where rule_family == "MASS_CLOUD_FILE_DOWNLOAD"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Mass Cloud File Download. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Mass Cloud File Download' involving user076@orionbank.example / WKS-492 and source 203.0.113.33.
09:03	Normalize	SOAR creates SOAR-076, stores raw event, extracts IP 203.0.113.33, domain case076-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.33 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.87 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-076.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.

- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-077 - Suspicious External Sharing

Domain: Cloud & SaaS

Objective	Remove unauthorized public/guest sharing and assess whether sensitive data was accessed.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New anonymous link, external guest share, or permission expansion affects sensitive repository.
ATT&CK v19.2 mapping	T1537 Transfer Data to Cloud Account; T1098 Account Manipulation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New anonymous link, external guest share, or permission expansion affects sensitive repository.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-077. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New anonymous link, external guest share, or permission expansion affects sensitive repository. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references

Step	SOAR / Analyst Action	Expected Output
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud audit logs before retention or tenant changes; compare activity to approved IaC/change records.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-077_SUSPICIOUS_EXTERNAL_SHARING
ON: alert where rule_family == "SUSPICIOUS_EXTERNAL_SHARING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:

```

```

        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Suspicious External Sharing. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Suspicious External Sharing' involving user077@orionbank.example / WKS-509 and source 203.0.113.40.
09:03	Normalize	SOAR creates SOAR-077, stores raw event, extracts IP 203.0.113.40, domain case077-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.40 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.98 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-077.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-078 - Public Cloud Storage Exposure

Domain: Cloud & SaaS

Objective	Detect and remediate storage buckets/containers made publicly accessible.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Cloud configuration/CSPM reports public ACL/policy or anonymous access to sensitive storage.
ATT&CK v19.2 mapping	T1530 Data from Cloud Storage
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Cloud configuration/CSPM reports public ACL/policy or anonymous access to sensitive storage.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-078. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Cloud configuration/CSPM reports public ACL/policy or anonymous access to sensitive storage. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
	after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-078_PUBLIC_CLOUD_STORAGE_EXPOSURE
ON: alert where rule_family == "PUBLIC_CLOUD_STORAGE_EXPOSURE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Public Cloud Storage Exposure. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Public Cloud Storage Exposure' involving user078@orionbank.example / WKS-526 and source 203.0.113.47.
09:03	Normalize	SOAR creates SOAR-078, stores raw event, extracts IP 203.0.113.47, domain case078-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.47 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.

Time	Stage	Simulation
09:05	Correlation	SOAR finds two related events from 198.51.100.109 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-078.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-079 - Cloud Audit Logging Disabled

Domain: Cloud & SaaS

Objective	Restore cloud visibility and treat unauthorized logging disablement as potential defense impairment.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	CloudTrail/Activity Log/Audit log/diagnostic setting is disabled, deleted, or retention reduced.
ATT&CK v19.2 mapping	T1562.008 Impair Defenses: Disable or Modify Cloud Logs
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWGWAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- CloudTrail/Activity Log/Audit log/diagnostic setting is disabled, deleted, or retention reduced.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-079. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: CloudTrail/Activity Log/Audit log/diagnostic setting is disabled, deleted, or retention reduced. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud audit logs before retention or tenant changes; compare activity to approved IaC/change records.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.

- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minute	60 (adjust for use case)
s	
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-079_CLOUD_AUDIT_LOGGING_DISABLED
ON: alert where rule_family == "CLOUD_AUDIT_LOGGING_DISABLED"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Cloud Audit Logging Disabled. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Cloud Audit Logging Disabled' involving user079@orionbank.example / WKS-543 and source 203.0.113.54.
09:03	Normalize	SOAR creates SOAR-079, stores raw event, extracts IP 203.0.113.54, domain case079-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.54 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.120 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-079.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-080 - AWS Root Account Use

Domain: Cloud & SaaS

Objective	Validate root-account usage and escalate unplanned access as critical.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	AWS root principal logs in or performs API action outside documented emergency procedure.
ATT&CK v19.2 mapping	T1078.004 Valid Accounts: Cloud Accounts
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- AWS root principal logs in or performs API action outside documented emergency procedure.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-080. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: AWS root	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	principal logs in or performs API action outside documented emergency procedure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-080_AWS_ROOT_ACCOUNT_USE
ON: alert where rule_family == "AWS_ROOT_ACCOUNT_USE"
DO:
    normalize(alert)

```

```

case = dedupe_or_create(correlation_key, window=60m)
enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for AWS Root Account Use. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'AWS Root Account Use' involving user080@orionbank.example / WKS-560 and source 203.0.113.61.
09:03	Normalize	SOAR creates SOAR-080, stores raw event, extracts IP 203.0.113.61, domain case080-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.61 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.131 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-080.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-081 - AWS Access Key Compromise

Domain: Cloud & SaaS

Objective	Disable or rotate compromised AWS access keys and determine actions performed with them.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision

Primary trigger	Access key appears in leak/secret scan or is used from unusual source/service/region.
ATT&CK v19.2 mapping	T1552 Unsecured Credentials; T1078.004 Valid Accounts: Cloud Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Access key appears in leak/secret scan or is used from unusual source/service/region.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-081. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Access key appears in leak/secret scan or is used from unusual source/service/region. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	audit logs before retention or tenant changes; compare activity to approved IaC/change records.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-081_AWS_ACCESS_KEY_COMPROMISE
ON: alert where rule_family == "AWS_ACCESS_KEY_COMPROMISE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for AWS Access Key Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'AWS Access Key

Time	Stage	Simulation
		Compromise' involving user081@orionbank.example / WKS-577 and source 203.0.113.68.
09:03	Normalize	SOAR creates SOAR-081, stores raw event, extracts IP 203.0.113.68, domain case081-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.68 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.142 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-081.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-082 - Azure Subscription Privilege Abuse

Domain: Cloud & SaaS

Objective	Detect unauthorized Azure role elevation or privileged resource changes and contain the identity.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	New Owner/Contributor assignment, privilege escalation, or sensitive resource change occurs suspiciously.
ATT&CK v19.2 mapping	T1098 Account Manipulation; T1078.004 Valid Accounts: Cloud Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- New Owner/Contributor assignment, privilege escalation, or sensitive resource change occurs suspiciously.

- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-082. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: New Owner/Contributor assignment, privilege escalation, or sensitive resource change occurs suspiciously. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: capture process tree and volatile evidence before destructive actions when feasible; hunt the same indicators/behavior across the fleet; isolate confirmed compromised endpoints according to critical-asset policy.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.

- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-082_AZURE_SUBSCRIPTION_PRIVILEGE_ABUSE
ON: alert where rule_family == "AZURE_SUBSCRIPTION_PRIVILEGE_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Azure Subscription Privilege Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Azure Subscription Privilege Abuse' involving user082@orionbank.example / WKS-594 and source 203.0.113.75.
09:03	Normalize	SOAR creates SOAR-082, stores raw event, extracts IP 203.0.113.75, domain case082-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.75 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.153 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-082.
09:20	Eradication / recovery	Root-cause remediation is completed, affected

Time	Stage	Simulation
		credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-083 - GCP Service Account Key Abuse

Domain: Cloud & SaaS

Objective	Revoke compromised GCP service-account keys and assess workload/data impact.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Service-account key is used from new network/workload, leaked, or creates anomalous resource access.
ATT&CK v19.2 mapping	T1552 Unsecured Credentials; T1078.004 Valid Accounts: Cloud Accounts
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Service-account key is used from new network/workload, leaked, or creates anomalous resource access.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-083. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields

Step	SOAR / Analyst Action	Expected Output
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Service-account key is used from new network/workload, leaked, or creates anomalous resource access. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-083_GCP_SERVICE_ACCOUNT_KEY_ABUSE
ON: alert where rule_family == "GCP_SERVICE_ACCOUNT_KEY_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for GCP Service Account Key Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'GCP Service Account Key Abuse' involving user083@orionbank.example / WKS-611 and source 203.0.113.82.
09:03	Normalize	SOAR creates SOAR-083, stores raw event, extracts IP 203.0.113.82, domain case083-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.82 as suspicious; CMDDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.164 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-083.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-084 - Cloud VM Cryptomining

Domain: Cloud & SaaS

Objective	Stop unauthorized compute consumption and identify compromised credentials/workloads.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Cloud cost/anomaly/EDR detects mining process, sustained CPU/GPU use, or suspicious mining pool traffic.
ATT&CK v19.2 mapping	T1496 Resource Hijacking
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Cloud cost/anomaly/EDR detects mining process, sustained CPU/GPU use, or suspicious mining pool traffic.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-084. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Cloud cost/anomaly/EDR detects mining process, sustained CPU/GPU use, or suspicious mining pool traffic. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows	Approved/denied/conditional action plan

Step	SOAR / Analyst Action	Expected Output
	confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud audit logs before retention or tenant changes; compare activity to approved IaC/change records.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-084_CLOUD_VM_CRYPTOMINING
ON: alert where rule_family == "CLOUD_VM_CRYPTOMINING"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```


7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Cloud VM Cryptomining. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Cloud VM Cryptomining' involving user084@orionbank.example / WKS-628 and source 203.0.113.89.
09:03	Normalize	SOAR creates SOAR-084, stores raw event, extracts IP 203.0.113.89, domain case084-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.89 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.175 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-084.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-085 - SaaS Admin Configuration Change

Domain: Cloud & SaaS

Objective	Validate high-impact SaaS security/admin changes and roll back unauthorized modifications.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Admin changes SSO, MFA, retention, audit, sharing, connector, or security policy outside change control.
ATT&CK v19.2 mapping	T1098 Account Manipulation; T1484 Domain or Tenant Policy Modification
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Admin changes SSO, MFA, retention, audit, sharing, connector, or security policy outside change control.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-085. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Admin changes SSO, MFA, retention, audit, sharing, connector, or security policy outside change control. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud audit logs before retention or tenant changes; compare activity to approved IaC/change records.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-085_SAAS_ADMIN_CONFIGURATION_CHANGE
ON: alert where rule_family == "SAAS_ADMIN_CONFIGURATION_CHANGE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for SaaS Admin Configuration Change. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'SaaS Admin Configuration Change' involving user085@orionbank.example / WKS-645 and source 203.0.113.96.
09:03	Normalize	SOAR creates SOAR-085, stores raw event, extracts IP 203.0.113.96, domain case085-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.96 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.186 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic

Time	Stage	Simulation
09:11	Containment	threshold satisfied or analyst one-click approval. Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-085.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-086 - Compromised OAuth / Enterprise Application

Domain: Cloud & SaaS

Objective	Disable malicious or compromised applications, revoke grants/secrets, and identify affected users/data.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	App registration/service principal shows unusual consent, credential change, permissions, or API activity.
ATT&CK v19.2 mapping	T1098 Account Manipulation; T1528 Steal Application Access Token
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- App registration/service principal shows unusual consent, credential change, permissions, or API activity.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-086. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host,	Single correlated incident

Step	SOAR / Analyst Action	Expected Output
	indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: App registration/service principal shows unusual consent, credential change, permissions, or API activity. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24

extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-086_COMPROMISED_OAUTH_ENTERPRISE_APPLICATION
ON: alert where rule_family == "COMPROMISED_OAUTH_ENTERPRISE_APPLICATION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Compromised OAuth / Enterprise Application. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Compromised OAuth / Enterprise Application' involving user086@orionbank.example / WKS-662 and source 203.0.113.103.
09:03	Normalize	SOAR creates SOAR-086, stores raw event, extracts IP 203.0.113.103, domain case086-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.103 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.197 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-086.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.

- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-087 - Cloud Snapshot / Backup Exfiltration

Domain: Cloud & SaaS

Objective	Stop unauthorized snapshot copy/share/export that can expose full data sets.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Snapshot, image, backup, or database export is copied to external account/region or made shareable.
ATT&CK v19.2 mapping	T1530 Data from Cloud Storage; T1020 Automated Exfiltration
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Snapshot, image, backup, or database export is copied to external account/region or made shareable.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-087. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Snapshot, image, backup, or database export is copied to external account/region or made shareable. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the	Evidence package references

Step	SOAR / Analyst Action	Expected Output
7. Run scoped hunt	case with timestamps and source system. Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: enumerate role, token, application and resource changes from the same principal; preserve cloud audit logs before retention or tenant changes; compare activity to approved IaC/change records.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-087_CLOUD_SNAPSHOT_BACKUP_EXFILTRATION
ON: alert where rule_family == "CLOUD_SNAPSHOT_BACKUP_EXFILTRATION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()

```

```

ELSE:
    request_analyst_decision()
    eradicate_root_cause()
    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Cloud Snapshot / Backup Exfiltration. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Cloud Snapshot / Backup Exfiltration' involving user087@orionbank.example / WKS-679 and source 203.0.113.110.
09:03	Normalize	SOAR creates SOAR-087, stores raw event, extracts IP 203.0.113.110, domain case087-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.110 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.208 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-087.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-088 - Cross-Tenant / Guest Account Abuse

Domain: Cloud & SaaS

Objective	Detect guest/B2B identities abusing access or gaining persistence across tenant boundaries.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Guest account accesses sensitive resources abnormally, receives elevated role, or is invited by compromised identity.
ATT&CK v19.2 mapping	T1078 Valid Accounts; T1098 Account Manipulation
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Cloud control-plane/audit logs and SaaS audit telemetry
- Cloud IAM identities, roles, tokens, service principals and permission graph
- CSPM/CIEM configuration findings and asset tags
- Cloud workload EDR/runtime/network logs where available
- Cloud-native response APIs for session revocation, key rotation, policy rollback and quarantine

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Guest account accesses sensitive resources abnormally, receives elevated role, or is invited by compromised identity.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-088. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Guest account accesses sensitive resources abnormally, receives elevated role, or is invited by compromised identity. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
	entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If the actor changed permissions, tokens, apps, or data-sharing state, roll back those changes and enumerate all actions by the same principal/session before recovery.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-088_CROSS_TENANT_GUEST_ACCOUNT_ABUSE
ON: alert where rule_family == "CROSS_TENANT_GUEST_ACCOUNT_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Cross-Tenant / Guest Account Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Cross-Tenant / Guest Account Abuse' involving user088@orionbank.example / WKS-696 and source 203.0.113.117.
09:03	Normalize	SOAR creates SOAR-088, stores raw event, extracts IP 203.0.113.117, domain case088-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.117 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.

Time	Stage	Simulation
09:05	Correlation	SOAR finds two related events from 198.51.100.219 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Revoke sessions/keys/tokens, remove unauthorized roles/apps/shares, quarantine or stop compromised workloads, restore audit controls, and preserve cloud activity logs/snapshots.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-088.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-089 - CI/CD Pipeline Compromise

Domain: DevSecOps & Containers

Objective	Contain compromised build/deployment pipelines and rotate secrets before malicious artifacts propagate.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Pipeline configuration, runner, workflow, or build job changes unexpectedly or executes suspicious commands.
ATT&CK v19.2 mapping	T1677 Poisoned Pipeline Execution; T1552 Unsecured Credentials
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Pipeline configuration, runner, workflow, or build job changes unexpectedly or executes suspicious commands.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-089. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Pipeline configuration, runner, workflow, or build job changes unexpectedly or executes suspicious commands. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: identify affected commits/builds/packages and downstream deployments; rotate repository/pipeline secrets; verify artifact provenance before resuming deployment.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.

- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-089_CI_CD_PIPELINE_COMPROMISE
ON: alert where rule_family == "CI_CD_PIPELINE_COMPROMISE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for CI/CD Pipeline Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'CI/CD Pipeline Compromise' involving user089@orionbank.example / WKS-713 and source 203.0.113.124.
09:03	Normalize	SOAR creates SOAR-089, stores raw event, extracts IP 203.0.113.124, domain case089-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.124 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.230 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-089.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-090 - Poisoned Pipeline Execution / Malicious Workflow

Domain: DevSecOps & Containers

Objective	Detect malicious code inserted into trusted automation and prevent downstream package/deployment compromise.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Workflow file or build step is modified to steal credentials, alter artifacts, or invoke attacker infrastructure.
ATT&CK v19.2 mapping	T1677 Poisoned Pipeline Execution; T1195 Supply Chain Compromise
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Workflow file or build step is modified to steal credentials, alter artifacts, or invoke attacker infrastructure.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-090. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Workflow	Validated hypothesis/classification

Step	SOAR / Analyst Action	Expected Output
	file or build step is modified to steal credentials, alter artifacts, or invoke attacker infrastructure. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: identify affected commits/builds/packages and downstream deployments; rotate repository/pipeline secrets; verify artifact provenance before resuming deployment.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-090_POISONED_PIPELINE_EXECUTION_MALICIOUS_WORKFLOW
ON: alert where rule_family == "POISONED_PIPELINE_EXECUTION_MALICIOUS_WORKFLOW"
DO:

```

```

normalize(alert)
case = dedupe_or_create(correlation_key, window=60m)
enrich(case, asset, identity, threat_intel, change_context)
score = risk_score(confidence, criticality, interaction, intel, spread)
preserve_evidence(case)
hunt(case, lookback=24h)
IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
ELSE:
    IF score >= 85 AND not critical_exception:
        execute_guarded_containment()
    ELSE:
        request_analyst_decision()
        eradicate_root_cause()
        recover_and_monitor()
        close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Poisoned Pipeline Execution / Malicious Workflow. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Poisoned Pipeline Execution / Malicious Workflow' involving user090@orionbank.example / WKS-730 and source 203.0.113.131.
09:03	Normalize	SOAR creates SOAR-090, stores raw event, extracts IP 203.0.113.131, domain case090-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.131 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.241 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-090.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-091 - Malicious Package / Dependency Supply Chain

Domain: DevSecOps & Containers

Objective	Block malicious dependencies/packages and identify affected builds, developers, and deployed artifacts.
-----------	---

Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	Package scanner/repository intelligence flags malicious or typosquatted dependency; install triggers suspicious behavior.
ATT&CK v19.2 mapping	T1195.001 Supply Chain Compromise: Compromise Software Dependencies and Development Tools; T1204.005 User Execution: Malicious Library
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Package scanner/repository intelligence flags malicious or typosquatted dependency; install triggers suspicious behavior.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-091. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Package scanner/repository intelligence flags malicious or typosquatted dependency; install triggers suspicious behavior. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: identify affected commits/builds/packages and downstream deployments; rotate repository/pipeline secrets; verify artifact provenance before resuming deployment.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-091_MALICIOUS_PACKAGE_DEPENDENCY_SUPPLY_CHAIN
ON: alert where rule_family == "MALICIOUS_PACKAGE_DEPENDENCY_SUPPLY_CHAIN"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Malicious Package / Dependency Supply Chain. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Malicious Package / Dependency Supply Chain' involving user091@orionbank.example / WKS-747 and source 203.0.113.138.
09:03	Normalize	SOAR creates SOAR-091, stores raw event, extracts IP 203.0.113.138, domain case091-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.138 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.2 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-091.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-092 - Repository Token / PAT Compromise

Domain: DevSecOps & Containers

Objective	Revoke compromised code-repository tokens and investigate commits, secrets, releases, and workflow abuse.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	PAT/token is leaked or used from unusual source to clone, push, modify workflows, or access secrets.
ATT&CK v19.2 mapping	T1528 Steal Application Access Token; T1078 Valid Accounts
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- PAT/token is leaked or used from unusual source to clone, push, modify workflows, or access secrets.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-092. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: PAT/token is leaked or used from unusual source to clone, push, modify workflows, or access secrets. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: revoke active sessions/refresh tokens where supported; check privilege and authentication-method changes; review sign-ins before and after the detection for blast radius.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-	Closed case + metrics + lessons

Step	SOAR / Analyst Action	Expected Output
	lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-092_REPOSITORY_TOKEN_PAT_COMPROMISE
ON: alert where rule_family == "REPOSITORY_TOKEN_PAT_COMPROMISE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Repository Token / PAT Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Repository Token / PAT Compromise' involving user092@orionbank.example / WKS-764 and source 203.0.113.145.
09:03	Normalize	SOAR creates SOAR-092, stores raw event, extracts IP 203.0.113.145, domain case092-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.145 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.13 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.

Time	Stage	Simulation
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-092.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-093 - Code Signing Key Compromise

Domain: DevSecOps & Containers

Objective	Protect software trust by revoking compromised signing credentials and identifying unauthorized signed artifacts.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Signing key/certificate is exposed, used unexpectedly, or signs unapproved artifact/build.
ATT&CK v19.2 mapping	T1552.004 Unsecured Credentials: Private Keys; T1587.002 Develop Capabilities: Code Signing Certificates
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Signing key/certificate is exposed, used unexpectedly, or signs unapproved artifact/build.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-093. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and	Normalized case + raw evidence link

Step	SOAR / Analyst Action	Expected Output
	raw-event references. Preserve the original alert payload.	
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Signing key/certificate is exposed, used unexpectedly, or signs unapproved artifact/build. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: identify affected commits/builds/packages and downstream deployments; rotate repository/pipeline secrets; verify artifact provenance before resuming deployment.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minute	60 (adjust for use case)
----------------------------------	--------------------------

s	
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-093_CODE_SIGNING_KEY_COMPROMISE
ON: alert where rule_family == "CODE_SIGNING_KEY_COMPROMISE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Code Signing Key Compromise. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Code Signing Key Compromise' involving user093@orionbank.example / WKS-781 and source 203.0.113.152.
09:03	Normalize	SOAR creates SOAR-093, stores raw event, extracts IP 203.0.113.152, domain case093-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.152 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.24 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-093.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.

- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-094 - Kubernetes Suspicious Exec / Privilege Abuse

Domain: DevSecOps & Containers

Objective	Detect unauthorized kubectl exec, privileged pod creation, secret access, or cluster-admin activity.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	Audit logs show exec/attach, secret listing, privileged container, role binding, or anomalous service-account action.
ATT&CK v19.2 mapping	T1609 Container Administration Command; T1611 Escape to Host
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Audit logs show exec/attach, secret listing, privileged container, role binding, or anomalous service-account action.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-094. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Audit logs show exec/attach, secret listing, privileged container, role binding, or anomalous service-account action. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant	Evidence package references

Step	SOAR / Analyst Action	Expected Output
	logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: identify affected commits/builds/packages and downstream deployments; rotate repository/pipeline secrets; verify artifact provenance before resuming deployment.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-094_KUBERNETES_SUSPICIOUS_EXEC_PRIVILEGE_ABUSE
ON: alert where rule_family == "KUBERNETES_SUSPICIOUS_EXEC_PRIVILEGE_ABUSE"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:

```

```

        classify("Expected / Benign"); close()
    ELSE:
        IF score >= 85 AND not critical_exception:
            execute_guarded_containment()
        ELSE:
            request_analyst_decision()
            eradicate_root_cause()
            recover_and_monitor()
            close_with_metrics_and_lessons()
    ON_ERROR:
        retry(3, exponential_backoff)
        route_to("SOC-L2 / Incident Response")
        never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Kubernetes Suspicious Exec / Privilege Abuse. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Kubernetes Suspicious Exec / Privilege Abuse' involving user094@orionbank.example / WKS-798 and source 203.0.113.159.
09:03	Normalize	SOAR creates SOAR-094, stores raw event, extracts IP 203.0.113.159, domain case094-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.159 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.35 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-094.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-095 - Container Escape / Privileged Container

Domain: DevSecOps & Containers

Objective	Contain workloads attempting to escape containers or abuse host mounts/capabilities.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Runtime security detects namespace escape, privileged container abuse, host filesystem mount, or suspicious kernel action.
ATT&CK v19.2 mapping	T1611 Escape to Host

Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- Git/repository audit logs, workflow/pipeline history and commit metadata
- CI/CD runner logs, package registry, artifact repository and secret-scanning telemetry
- Kubernetes/cloud audit logs and runtime security telemetry
- Developer/service account identities, PATs, signing keys and build secrets
- SBOM/package intelligence and deployment inventory

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Runtime security detects namespace escape, privileged container abuse, host filesystem mount, or suspicious kernel action.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-095. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Runtime security detects namespace escape, privileged container abuse, host filesystem mount, or suspicious kernel action. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established. Specific actions: identify affected commits/builds/packages and downstream	Action results + API audit

Step	SOAR / Analyst Action	Expected Output
	deployments; rotate repository/pipeline secrets; verify artifact provenance before resuming deployment.	
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If artifact integrity is uncertain, stop promotion/deployment and quarantine affected build outputs until a clean rebuild from trusted source succeeds.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-095_CONTAINER_ESCAPE_PRIVILEGED_CONTAINER
ON: alert where rule_family == "CONTAINER_ESCAPE_PRIVILEGED_CONTAINER"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Container Escape / Privileged Container. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Container Escape / Privileged Container' involving user095@orionbank.example / WKS-815 and source 203.0.113.166.
09:03	Normalize	SOAR creates SOAR-095, stores raw event, extracts IP 203.0.113.166, domain case095-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.166 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.46 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Pause affected pipeline/release, revoke developer and automation tokens, quarantine artifacts/packages, isolate runners/workloads, and prevent further deployment until integrity is re-established.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-095.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-096 - DLP Sensitive Data Exfiltration

Domain: Data Protection & Resilience

Objective	Stop exfiltration of regulated or sensitive data through email, web, cloud, removable media, or collaboration channels.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	DLP policy detects high-confidence sensitive-data transfer beyond approved destination or volume.
ATT&CK v19.2 mapping	T1048 Exfiltration Over Alternative Protocol; T1567 Exfiltration Over Web Service
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- DLP/CASB, database audit, file-access and cloud storage telemetry
- Data classification, sensitivity labels and business owner context
- Identity/endpoint/network context for the user and device
- Backup platform audit, immutability/retention status and restore health
- Legal/privacy/compliance escalation matrix where applicable

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- DLP policy detects high-confidence sensitive-data transfer beyond approved destination or volume.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-096. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: DLP policy detects high-confidence sensitive-data transfer beyond approved destination or volume. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met. Specific actions: validate data classification and actual egress/access; separate malicious behavior from approved bulk business activity; record privacy/regulatory impact assessment when thresholds are met.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If regulated/sensitive data is confirmed exposed or recovery capability is impaired, activate the defined legal/privacy/major-incident escalation path.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```
PLAYBOOK: PB-096_DLP_SENSITIVE_DATA_EXFILTRATION
ON: alert where rule_family == "DLP_SENSITIVE_DATA_EXFILTRATION"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure
```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for DLP Sensitive Data Exfiltration. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'DLP Sensitive Data Exfiltration' involving user096@orionbank.example / WKS-832 and source 203.0.113.173.
09:03	Normalize	SOAR creates SOAR-096, stores raw event, extracts IP 203.0.113.173, domain case096-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.173 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.57 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met.

Time	Stage	Simulation
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-096.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-097 - Database Bulk Export / Dump

Domain: Data Protection & Resilience

Objective	Detect and contain unusually large database queries, exports, dumps, or backup extraction.
Default severity	High
Target SLA	10 min acknowledge / 30 min containment decision
Primary trigger	DB audit/DAM detects high-volume SELECT/export, dump utility, backup copy, or data access outside baseline.
ATT&CK v19.2 mapping	T1213 Data from Information Repositories; T1005 Data from Local System
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- DLP/CASB, database audit, file-access and cloud storage telemetry
- Data classification, sensitivity labels and business owner context
- Identity/endpoint/network context for the user and device
- Backup platform audit, immutability/retention status and restore health
- Legal/privacy/compliance escalation matrix where applicable

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- DB audit/DAM detects high-volume SELECT/export, dump utility, backup copy, or data access outside baseline.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-097. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint,	Criticality/reputation/context fields

Step	SOAR / Analyst Action	Expected Output
	network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: DB audit/DAM detects high-volume SELECT/export, dump utility, backup copy, or data access outside baseline. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If regulated/sensitive data is confirmed exposed or recovery capability is impaired, activate the defined legal/privacy/major-incident escalation path.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff

manual fallback queue	SOC-L2 / Incident Response
evidence retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-097_DATABASE_BULK_EXPORT_DUMP
ON: alert where rule_family == "DATABASE_BULK_EXPORT_DUMP"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a high alert for Database Bulk Export / Dump. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Database Bulk Export / Dump' involving user097@orionbank.example / WKS-849 and source 203.0.113.180.
09:03	Normalize	SOAR creates SOAR-097, stores raw event, extracts IP 203.0.113.180, domain case097-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.180 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.68 and links them to the same case. Risk score increases to 74/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-097.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.

- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-098 - Insider Threat Anomalous Access

Domain: Data Protection & Resilience

Objective	Combine identity, HR-approved context, DLP, and behavioral signals to investigate potentially harmful authorized-user activity with strict privacy controls.
Default severity	Medium-High
Target SLA	15 min acknowledge / 60 min containment decision
Primary trigger	User accesses unusual sensitive data, performs abnormal bulk actions, or changes behavior beyond peer baseline.
ATT&CK v19.2 mapping	T1078 Valid Accounts; T1213 Data from Information Repositories
Automation posture	Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- DLP/CASB, database audit, file-access and cloud storage telemetry
- Data classification, sensitivity labels and business owner context
- Identity/endpoint/network context for the user and device
- Backup platform audit, immutability/retention status and restore health
- Legal/privacy/compliance escalation matrix where applicable

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- User accesses unusual sensitive data, performs abnormal bulk actions, or changes behavior beyond peer baseline.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-098. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Medium-High; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: User accesses unusual sensitive data, performs abnormal bulk actions, or changes behavior beyond peer baseline. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-	Blast-radius result set

Step	SOAR / Analyst Action	Expected Output
	chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Auto-triage with guarded response: enrichment, deduplication, hunting and ticket updates are automatic; containment follows confidence/criticality thresholds. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met. Specific actions: validate data classification and actual egress/access; separate malicious behavior from approved bulk business activity; record privacy/regulatory impact assessment when thresholds are met.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If regulated/sensitive data is confirmed exposed or recovery capability is impaired, activate the defined legal/privacy/major-incident escalation path.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-098_INSIDER_THREAT_ANOMALOUS_ACCESS
ON: alert where rule_family == "INSIDER_THREAT_ANOMALOUS_ACCESS"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()

```

```

    eradicate_root_cause()
    recover_and_monitor()
    close_with_metrics_and_lessons()
ON_ERROR:
    retry(3, exponential_backoff)
    route_to("SOC-L2 / Incident Response")
    never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a medium-high alert for Insider Threat Anomalous Access. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Insider Threat Anomalous Access' involving user098@orionbank.example / WKS-866 and source 203.0.113.187.
09:03	Normalize	SOAR creates SOAR-098, stores raw event, extracts IP 203.0.113.187, domain case098-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.187 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.79 and links them to the same case. Risk score increases to 66/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates credible malicious attempt requiring containment review.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: automatic threshold satisfied or analyst one-click approval.
09:11	Containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-098.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Malicious Attempt / Contained with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-099 - Backup Tampering / Recovery Impairment

Domain: Data Protection & Resilience

Objective	Protect recovery capability when attackers delete snapshots, disable jobs, change retention, or access backup admin controls.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	Backup platform reports deletion, immutability change, retention reduction, job disablement, or suspicious admin access.
ATT&CK v19.2 mapping	T1490 Inhibit System Recovery; T1562 Impair Defenses
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- DLP/CASB, database audit, file-access and cloud storage telemetry
- Data classification, sensitivity labels and business owner context
- Identity/endpoint/network context for the user and device
- Backup platform audit, immutability/retention status and restore health
- Legal/privacy/compliance escalation matrix where applicable

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- Backup platform reports deletion, immutability change, retention reduction, job disablement, or suspicious admin access.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.
- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-099. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: Backup platform reports deletion, immutability change, retention reduction, job disablement, or suspicious admin access. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met. Specific actions: validate data classification and actual egress/access; separate malicious behavior from approved bulk business activity; record privacy/regulatory impact assessment when thresholds are met.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only	Trusted state + watch period

Step	SOAR / Analyst Action	Expected Output
	after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.
- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If regulated/sensitive data is confirmed exposed or recovery capability is impaired, activate the defined legal/privacy/major-incident escalation path.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-099_BACKUP_TAMPERING_RECOVERY_IMPAIRMENT
ON: alert where rule_family == "BACKUP_TAMPERING_RECOVERY_IMPAIRMENT"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Backup Tampering / Recovery Impairment. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Backup Tampering / Recovery Impairment' involving user099@orionbank.example / WKS-883 and source 203.0.113.194.
09:03	Normalize	SOAR creates SOAR-099, stores raw event, extracts IP 203.0.113.194, domain case099-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.194 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is

Time	Stage	Simulation
09:05	Correlation	found. SOAR finds two related events from 198.51.100.90 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Stop the transfer or access path, suspend risky sessions if justified, preserve access evidence, protect backup/recovery systems, and involve privacy/legal only when defined impact thresholds are met.
09:14	Enterprise hunt	Search across the prior 24h finds one additional related entity; all hits are attached to SOAR-099.
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

PB-100 - Multi-Stage Major Incident / Enterprise Orchestrator

Domain: Major Incident Management

Objective	Correlate multiple alerts into a single major incident, coordinate cross-domain containment, preserve evidence, and manage recovery.
Default severity	Critical
Target SLA	5 min acknowledge / 15 min containment decision
Primary trigger	High-confidence chain spans multiple domains (identity + endpoint + network + data) or material business impact threshold is met.
ATT&CK v19.2 mapping	Multiple ATT&CK tactics; use incident-specific mapping across Initial Access, Execution, Persistence, Privilege Escalation, Credential Access, Discovery, Lateral Movement, Collection, C2, Exfiltration, Impact, Stealth, Defense Impairment
Automation posture	Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval.
Primary case entity	Identity / endpoint / message / network indicator / resource as applicable; use a stable correlation key.
Recommended lookback	24 hours initial; extend to 7-30 days for identity persistence, cloud, email rules, supply-chain, data exfiltration or suspected long dwell time.

1. Required Data and Connectors

- All normalized alerts/incidents from SIEM, EDR, IAM, email, network, cloud and DLP
- Asset/identity criticality and business service dependency mapping
- Case-management timeline, evidence repository and communications channel
- Threat-intelligence and attack-path context
- Executive/legal/regulatory escalation contacts and recovery owners

Recommended reference connector mapping: SIEM/SOAR (e.g., QRadar/Splunk/Sentinel equivalent), EDR (e.g., Trellix/Defender/CrowdStrike equivalent), email/M365 or Google Workspace, firewall/SWG/WAF/IPS/NDR, threat intelligence, CMDB/ITSM, cloud control plane and DLP as relevant.

2. Trigger and Entry Conditions

- High-confidence chain spans multiple domains (identity + endpoint + network + data) or material business impact threshold is met.
- Minimum required fields: detection timestamp, source product/rule, one primary entity, raw-event reference, confidence/severity, and a stable correlation identifier.

- Do not start a disruptive response if the alert cannot be tied to an entity. Route incomplete alerts to a data-quality/manual-triage queue.
- Suppress known synthetic tests only when the test window, owner and expected indicator are all validated.

3. Step-by-Step SOAR Workflow

Step	SOAR / Analyst Action	Expected Output
1. Ingest and normalize	Create or update case SOAR-100. Parse the originating alert into a common schema: detection time, source product, rule ID, user, host, IP, URL/domain/hash, cloud resource, severity, and raw-event references. Preserve the original alert payload.	Normalized case + raw evidence link
2. Deduplicate and correlate	Search open cases for the same identity, host, indicator, message, application, or resource during the configured correlation window. Merge related alerts and append evidence so the analyst works one incident rather than many duplicates.	Single correlated incident
3. Enrich context	Query CMDB/asset inventory, identity directory, threat intelligence, recent authentication, endpoint, network and change-management data. Add business criticality, owner, privileged status, exposure, reputation and recent related detections.	Criticality/reputation/context fields
4. Score risk	Calculate incident score using detection confidence + entity criticality + confirmed interaction/impact + threat-intel confidence + number of correlated signals. Default severity for this playbook is Critical; automatically raise one level for privileged identities or critical production assets.	Risk score + severity
5. Validate the trigger	Test the core hypothesis for this use case: High-confidence chain spans multiple domains (identity + endpoint + network + data) or material business impact threshold is met. Confirm whether the activity is real, expected, blocked/prevented, or evidence of successful compromise. Record the evidence used for the classification.	Validated hypothesis/classification
6. Preserve evidence	Before destructive remediation, capture the relevant logs, message/file metadata, process tree, authentication trail, configuration diff, API/audit events, and key IOC values. Store references in the case with timestamps and source system.	Evidence package references
7. Run scoped hunt	Search the previous 24 hours by default (extend to 7-30 days for identity, cloud, persistence or supply-chain cases) for the same IOC, account, process, file, sender, token/app, source IP or behavior across the enterprise.	Blast-radius result set
8. Make containment decision	Evaluate confidence, spread, asset criticality and business impact. Human-approved containment: enrichment and evidence collection can be automatic; disruptive containment requires analyst/incident-commander approval. Apply exception logic before any action that could interrupt critical services.	Approved/denied/conditional action plan
9. Execute containment	Create one parent major incident, freeze destructive automation that could lose evidence, execute prioritized containment by business impact, establish incident command, and coordinate recovery with explicit decision logs. Specific actions: pivot on source/destination across firewall, DNS, proxy and EDR; block indicators only after allow-list/business-critical validation; check for successful sessions or payload delivery rather than closing on a block event alone.	Action results + API audit
10. Eradicate root cause	Remove persistence or malicious artifacts, patch/misconfiguration where applicable, rotate exposed credentials/secrets, remove unauthorized permissions/rules/apps, and open remediation tasks for control gaps that cannot be fixed safely inside SOAR.	Remediation tasks completed/assigned
11. Recover and monitor	Return the asset/identity/service to production only after recovery checks pass. Monitor the same entities and indicators at heightened sensitivity for at least 24 hours for endpoint events and 72 hours for identity/cloud incidents, unless organizational policy requires longer.	Trusted state + watch period
12. Close and improve	Document final classification, impact, containment actions, root cause, affected entities, evidence, timeline, residual risk and owner. Update allow-lists/detections/playbook thresholds only through controlled review; capture lessons learned and metrics.	Closed case + metrics + lessons

4. Decision Logic and Approval Gates

- If the signal is on an approved allow-list or matches an active change/test window, tag as expected activity and require evidence before closing.

- If confidence is below the containment threshold, keep the case in investigation state and run additional pivots rather than taking disruptive action.
- If the affected identity or asset is privileged, executive, break-glass, domain controller, payment/core service, or production control-plane, require explicit approval before disable/isolation unless an emergency policy says otherwise.
- If the same IOC/entity appears in multiple alerts within the deduplication window, merge into the existing case and increase the incident score rather than opening duplicates.
- If regulated/sensitive data is confirmed exposed or recovery capability is impaired, activate the defined legal/privacy/major-incident escalation path.

5. Recommended SOAR Variables

correlation_window_minutes	60 (adjust for use case)
initial_lookback_hours	24
extended_lookback_days	7 or 30 when persistence/identity/cloud/data applies
auto_contain_score	85/100 default; lower only for high-confidence active threats
approval_required	true for critical/VIP/privileged/core-service actions
block_ttl_hours	24 default for dynamic IOC block; convert to permanent only after review
max_connector_retries	3 with exponential backoff
manual_fallback_queue	SOC-L2 / Incident Response
evidence_retention	Follow organizational/regulatory policy; preserve raw event and action audit trail

6. Implementation Pseudocode

```

PLAYBOOK: PB-100_MULTI_STAGE_MAJOR_INCIDENT_ENTERPRISE_ORCHESTRATOR
ON: alert where rule_family == "MULTI_STAGE_MAJOR_INCIDENT_ENTERPRISE_ORCHESTRATOR"
DO:
  normalize(alert)
  case = dedupe_or_create(correlation_key, window=60m)
  enrich(case, asset, identity, threat_intel, change_context)
  score = risk_score(confidence, criticality, interaction, intel, spread)
  preserve_evidence(case)
  hunt(case, lookback=24h)
  IF expected_change_or_allowlist AND evidence_is_clean:
    classify("Expected / Benign"); close()
  ELSE:
    IF score >= 85 AND not critical_exception:
      execute_guarded_containment()
    ELSE:
      request_analyst_decision()
      eradicate_root_cause()
      recover_and_monitor()
      close_with_metrics_and_lessons()
ON_ERROR:
  retry(3, exponential_backoff)
  route_to("SOC-L2 / Incident Response")
  never_mark_closed_on_action_failure

```

7. Full Simulation Example

Scenario: Orion Bank (fictional) receives a critical alert for Multi-Stage Major Incident / Enterprise Orchestrator. The example uses reserved documentation IP ranges and the .example domain so no real infrastructure is referenced.

Time	Stage	Simulation
09:02	Detection	SIEM receives alert for 'Multi-Stage Major Incident / Enterprise Orchestrator' involving user100@orionbank.example / WKS-900 and source 203.0.113.201.
09:03	Normalize	SOAR creates SOAR-100, stores raw event, extracts IP 203.0.113.201, domain case100-verify.example and relevant entity identifiers.
09:04	Enrichment	Threat intelligence scores 203.0.113.201 as suspicious; CMDB marks the entity as normal business criticality; no approved change window is found.
09:05	Correlation	SOAR finds two related events from 198.51.100.101 and links them to the same case. Risk score increases to 82/100.
09:07	Validation	Analyst confirms the activity matches the playbook hypothesis and is not a known test. Evidence indicates successful or active impact.
09:09	Containment decision	SOAR checks critical-asset and privileged-identity exception lists. Required approval state: incident commander approval.
09:11	Containment	Create one parent major incident, freeze destructive automation that could lose evidence, execute prioritized containment by business impact, establish incident command, and coordinate recovery with explicit decision logs.
09:14	Enterprise hunt	Search across the prior 24h finds no additional confirmed compromise; all hits are attached to SOAR-100.

Time	Stage	Simulation
09:20	Eradication / recovery	Root-cause remediation is completed, affected credentials/configuration/artifacts are restored to a trusted state, and monitoring is increased.
Next business day	Closure	Case is closed as Confirmed Incident with complete timeline, evidence links, action audit trail and follow-up control task.

8. Validation, Closure Criteria and KPIs

- Positive-path test: inject a synthetic alert with all required fields and confirm enrichment, scoring, hunt, decision, containment simulation, evidence and ticket updates execute in the correct order.
- False-positive test: use an approved change/test indicator and confirm the playbook does not perform disruptive containment.
- Connector-failure test: force one write API to fail and confirm retries occur, the case remains open, and a manual task is generated.
- Idempotency test: rerun the same alert and confirm there is no duplicate case or duplicate containment action.
- Closure requires: trigger validated, blast radius assessed, all containment actions successful or manually documented, root cause remediated/assigned, recovery checks passed, evidence retained and final classification recorded.
- KPIs: alert-to-case time, analyst acknowledgement time, containment decision time, mean time to contain, number of analyst touches, automation success %, false-positive %, retry/failure %, number of affected entities, and recurrence within 7 days.

Appendix A - Suggested Severity and Containment Policy

Critical	Active destructive attack, privileged/break-glass compromise, confirmed major data impact, domain/cloud control-plane compromise, public-facing exploitation with execution, or recovery-system impairment. Immediate incident command. Automated evidence; disruptive actions normally approved unless emergency policy explicitly pre-authorizes.
High	Confirmed compromise or highly credible activity with successful authentication/execution, token theft, C2, exposed secrets, pipeline compromise, sensitive data access or attack propagation. Rapid containment with guarded automation.
Medium-High	Credible malicious attempt, blocked exploit/phish, anomalous behavior needing investigation, or a single control alert without confirmed downstream impact. Automate triage/hunt; contain after validation.

Appendix B - Common Case Schema

case_id
playbook_id
state
created_time
updated_time
detection_time
source_product
source_rule_id
raw_event_ref
severity
confidence
risk_score
classification
user_id
user_type
privileged_flag
host_id
asset_criticality
business_service
source_ip
destination_ip
domain
url
sha256
message_id
cloud_resource
application_id
token_or_key_id
data_classification
mitre_techniques
related_case_ids
approval_state
approver
containment_actions
action_results
evidence_refs
root_cause
impact
recovery_status
monitor_until
owner
ticket_id
change_id
lessons_learned
closure_reason

Appendix C - Production Readiness Checklist

- All 100 playbooks have named business owners and technical owners.
- Required log sources are present, time-synchronized and retained long enough for the configured hunt windows.
- Write-action connectors use least-privilege accounts and are protected by secrets management.
- Critical asset/VIP/break-glass/service-account exception lists are populated and reviewed.
- Every disruptive action has documented approval policy, rollback procedure and API failure handling.
- Every IOC block has an owner, reason, source confidence, timestamp and expiry/TTL.
- Evidence storage and action audit are immutable enough for internal investigation requirements.
- Major-incident communication, legal/privacy/regulatory, vendor and executive escalation paths are pre-defined.
- Each playbook has passed positive, negative, failure, idempotency and rollback tests.
- Metrics dashboards track time-to-respond, time-to-contain, automation %, false positives and connector reliability.

Appendix D - 2026 Reference Sources

Source	Use in this handbook	Reference
NIST SP 800-61 Rev. 3 (April 2025)	Incident Response Recommendations and	https://csrc.nist.gov/pubs/sp/800/61/r3/final

Source	Use in this handbook	Reference
	Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile	
NIST IR 8374 Rev. 1 (June 2026)	Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile	https://csrc.nist.gov/pubs/ir/8374/r1/final
MITRE ATT&CK v19.2 (August 2026)	Current ATT&CK release notes and v19.2 agile update	https://attack.mitre.org/resources/updates/updates-august-2026/
MITRE ATT&CK v19 (April 2026)	Enterprise tactic changes, including Stealth and Defense Impairment	https://attack.mitre.org/resources/updates/updates-april-2026/
MITRE ATT&CK - Kali365 (S9044)	2026 PHaaS/device-code/AiTM/session-token activity	https://attack.mitre.org/software/S9044/
MITRE ATT&CK - TeamPCP (G1056)	2026 cloud-native CI/CD and software supply-chain activity	https://attack.mitre.org/groups/G1056/
MITRE ATT&CK - Shai-Hulud (S9008)	Software supply-chain worm targeting code repositories and package ecosystems	https://attack.mitre.org/software/S9008/
Microsoft Defender XDR (updated June 2026)	Compromised identity incident response SOP template	https://learn.microsoft.com/en-us/defender-xdr/sop-documentation-template
CISA	Federal Government Cybersecurity Incident and Vulnerability Response Playbooks	https://www.cisa.gov/topics/cybersecurity-best-practices/executive-order-improving-nations-cybersecurity
CISA	Phishing Guidance: Stopping the Attack Cycle at Phase One	https://www.cisa.gov/resources-tools/resources/phishing-guidance-stopping-attack-cycle-phase-one

End of handbook